

Siber Güvenlik

101 BİTİRME PROJESİ: "The Analyst & The Hunter"

Saniye Topal

12.03.2026

İÇİNDEKİLER

- Bölüm A: Teori ve Mimari (Research & Logic)

1. İşletim Sistemi ve Şifreleme: "Anahtarlar

Kimde?"

2. Web Mimarisi: "Sunucu Tarafı (Server-Side)"

3. Ağ Anatomisi: "Avin İzleri"

- Bölüm B: Saha Operasyonu (Boss Fights)

Cephe 1: İşletim Sistemleri Ustası (Linux / Bash)

Cephe 2: Web Mantık Avcısı (Server-Side)

Cephe 3: Kör Nokta Dedektifi (Ağ Adli Analizi)

- BÖLÜM C: Av Mevsimi (Saha Adımları)

Cephe 1: Hedef Seçimi ve Keşif (Recon Haritası)

Cephe 2: Zafiyet Avı (Vulnerability Assessment)

Cephe 3: Profesyonel Raporlama (Kritik

Teslimat

- BÖLÜM D: Mühendislik Vizyonu (Reflection)

1. Etki Analizi (Impact & CVSS Mantiği)

2. Çözüm Üretmek (Mitigation)

101 Bitirme Projesi:”The Analyst and The Hunter”

Bölüm A: Teori ve Mimari (Research and Logic)

1.İşletim Sistemi ve Şifreleme : Anahtarlar Kimde?

SSH Pivate Key (Gizli Anahtar): Parola ile güvenlik sağlama kolay yöntemlerden biridir ancak Brute Force gibi saldırılara karşı savunmasız kalabilir. SSH ise asimetrik şifreleme yöntemi ile çalışır. Asimetrik şifreleme yönteminde public sunucuda ve private kullanıcıda olmak üzere 2 tane anahtar bulunur. Bir bağlantı isteği gönderildiğinde sunucu public keyle bazı şifre ve verileri private keye gönderir. Eğer public key ile private key eşleşiyorsa private key gönderilen veri ve şifreleri çözerek sunucuya gönderir. Sunucunun onaylaması ile kimlik doğrulaması gerçekleşir. Ve sunucu simetrik şifreleme anahtarlar ile tüm işlemlerinizi gizlilikle yürütür.

Hex Dump Nedir ?: Bir dosyanın veya bilgisayardaki bellek bölgesinin ham verilerinin onaltılık sayı sistemi kullanılarak gösterilmesi sağlayan komut satırı aracıdır. Hex dump çıktısı 3 ana satırdan oluşur. Offset adres (satır dosyasının kaçınıcı bayttan başladığını gösterir.) , hexadecimal veri sütunu (verinin kendisini içerir.) ve ASCII (hex değerlerinin metinsel olarak karşılığını gösterir.) kısımlarından oluşur. Bu şekilde dosya yapısı analiz edilir örneğin dosyada virüs olup olmadığı, değişkenin bellekte nasıl durduğunu, malware yazılıma sahip olup olmadığı gibi dosya hakkında bilgi vererek farklı amaçlarda kullanılabilir.

2.Web Mimarisi : “Sunucu Tarafı (Server-Side)”

Client-Side ve Server-Side: Bir kullanıcı client-side ve server-side -lardan client side yazılımlarını genellikle HTML veya JavaScript görebilirken server-side yazılımlarını genellikle PHP veya Python göremez. Bunun nedeni kodun çalıştığı yere ve ne tür veriler barındırdığıyla ilgilidir. Client -side lar kullanıcı , istemci tarafıdır örneğin bir web tarayıcısında yazdığınız bir siteye gitmek istediğinizde bu isteği client-side server-side a HTML veya JavaScript gibi yazılımlarla iletir. Server-side ise sunucu tarafıdır sunucu gelen isteği alır ve arka planda çalışan PHP veya Python kodlarını kullanarak gerekli hesaplamaları yapar ve veritabanı kodlarına ulaşmak zorundadır yani kimlik bilgileri, şifreler gibi önemli verileri içerir ayrıca bir uygulamanın çalışma mantığı, veri yönetimi ve sunucu yapılandırmasıyla ilgili kodlar içerir. Bu kadar hassas bilgiler içerdiği için server-side da yazılan Python veya PHP gibi kodları kullanıcı göremez onun yerine server-side in barındırdığı verilerle oluşturduğu client- side a gönderdiği HTML veya JavaScript gibi kodlar kullanıcı tarafından görülebilir bu kodlar hassas veri içermez.

Command Injection(Komut Enjeksiyonu): Bir web uygulaması, kullanıcıdan aldığı veriyi kontrol etmeden işletim sistemine dahil etmesiyle oluşan zafiyettir. Web tarayıcısındaki arama motoruna yazılan bir metin bile işletim sisteminde kod yazmaya neden olabilir. Aynı zamanda bu saldırı çerezler veya formlar üzerinden de yapılabilir. Birçok web uygulaması işletim sistemiyle etkileşime girmek için shell_exec() veya system() gibi özel fonksiyonlar kullanır. Bu fonksiyonlar direkt olarak işletim sisteminin çekirdeğini ve kabuk katmanını etkiler. Kontrol edilmeden sistem komutuna işlenen metinler genellikle ; , && , | gibi komut ayırıcıları kullanılarak yazılan komutlarla sisteme örneğin ls(yazılan komuta göre dosya içindeki istenen türde verileri listeler) ve whoami (erişim yetkilerine bak düşük olasılıkla root değeri dönebilir , en üst yetki seviyesidir) komutlarını kullanarak resim.png; whoami index.php && ls -la kodları komut enjeksiyonunda kullanılan kodlara örnektir.

3.Ağ Anatomisi:”Avin İzleri”

C2(Command and Control) Nedir? : C2 (Command and Control), saldırganların sistem merkezlerini kontrol etmek ve kötü amaçlı yazılımlar yüklemek amacıyla kullandığı altyapıdır. Malware hedef sistemin yapısını ve güvenlik önlemlerini bilemez bundan dolayı hangi adımları yerine getireceğini C2 sunucusu belirler. İlk sızmayı gerçekleştiren yazılım , dosya boyutunu küçük tutmak ve imza tabanlı taramalardan kaçmak için asıl saldırı kodlarını içinde barındırmaz. C2 bağlantısıyla saldırgan sisteme daha ağır yazılımlar yükleyebilir. Malware topladığı verileri C2 sunucusuna ileterek verileri sızdırır. Eğer birden çok cihaz saldırmış ise C2 sunucusu ile hepsi birlikte, koordinasyonlu hareket edebilir. Ayrıca C2 bağlantısı , yazılımın kendini güncellemesini sağlayarak antivirüs (EDR) yazılımlarına yakalanmasını zorlaştırır.

PCAP Analizi: Bir SOC analisti zararlı yazılımları tespit etmek için sadece Antivirüs loglarına bakamaz, PCAP analizlerine de bakar. Bunun nedeni antivirüslerin çoğunlukla imza tabanlı çalışmasıdır yani yeni tür zararlı yazılımlar veya daha önce görülmemiş saldırılar antivirüs tarafından tespit edilemeyebilir. Ayrıca bazı zararlı yazılımlar fileless olarak çalışarak diske dosya bırakmadan direkt RAM üzerinden çalışabilir. Antivirüsler genelde disk üzerindeki dosyaları taradığı için bu tür zararlı yazılımları tespit edemeyebilir. PCAP ise ağ üzerinden geçen veri paketlerinin dijital kayıdır. PCAP araçları ağ kartını Promiscuos modda çalıştırarak ağ üzerinden geçen paketleri yakalayabilir ve analiz edilmesini sağlar. Bu sayede zararlı yazılımın ağ üzerindeki hareketleri, hangi IP adresleriyle iletişim kurduğu, C2 sunucularıyla bağlantısı veya şüpheli DNS sorguları görülebilir. Antivirüs logları saldırganla ilgili sınırlı bilgi verirken, PCAP analizinde paketler incelenerek saldırganın yaptığı bağlantılar, veri sızdırma girişimleri ve ağ üzerindeki hareketleri daha detaylı şekilde görülebilir.

Bölüm B: Saha Operasyonu (Boss Fights)

Cephe 1: İşletim Sistemleri Ustası (Linux/ Bash)

Level 11: tüm küçük (az) ve büyük (AZ) harflerin 13 pozisyon döndürüldüğü ROT13 şifrelemesiyle data.txt dosyasında level12 nin şifresi saklanmaktadır.

```
* gef (https://github.com/hugsy/gef) in /opt/gef/
* pwndbg (https://github.com/pwndbg/pwndbg) in /opt/pwndbg/
* gdbinit (https://github.com/gdbinit/Gdbinit) in /opt/gdbinit/
* pwntools (https://github.com/Gallopsled/pwntools)
* radare2 (http://www.radare.org/)

--[ More information ]--

For more information regarding individual wargames, visit
http://www.overthewire.org/wargames/

For support, questions or comments, contact us on discord or IRC.

Enjoy your stay!

bandit11@bandit:~$ tr 'A-Za-z' 'N-ZA-Mn-za-m'
cat data.txt | tr 'A-Za-z' 'N-ZA-Mn-za-m'
png qngn.gkg | ge 'N-Mn-m' 'A-MN-Za-mn-z'
^C
bandit11@bandit:~$ cat data.txt | tr 'A-Za-z' 'N-ZA-Mn-za-m'
The password is 7x16WNeHIi5YkIhWsfFIqoognUTyj9Q4
bandit11@bandit:~$ |
```

Level 12: Sonraki seviyenin şifresi, tekrar tekrar sıkıştırılmış bir dosyanın onaltılık dökümü olan data.txt dosyasında saklanır

```
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ bzip2 -d veri
bzip2: Can't guess original name for veri -- using veri.out
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ file veri.out
veri.out: gzip compressed data, was "data4.bin", last modified: Tue Oct 14 09:26:06 2025, max compression, from Unix, original size modulo 2^32 2048
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ mv veri.out veri.gz
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ gunzip veri.gz
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ file veri
veri: POSIX tar archive (GNU)
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ bzip tar -xf veri.out
Command 'bzip' not found, but there are 21 similar ones.
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ tar -xf veri
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ ls
data5.bin  data.txt  veri
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ file data5.bin
data5.bin: POSIX tar archive (GNU)
```

```
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ ls
data5.bin  data.txt  veri
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ tar -xf data5.bin
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ ls
data5.bin  data6.bin  data.txt  veri
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ file data6.bin
data6.bin: bzip2 compressed data, block size = 900k
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ bzip2 -d data6.bin
bzip2: Can't guess original name for data6.bin -- using data6.bin.out
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ file data6.bin.out
data6.bin.out: POSIX tar archive (GNU)
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ tar -xf data6.bin.out
tar: data6.bin.out: Cannot open: No such file or directory
tar: Error is not recoverable: exiting now
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ tar -xf data6.bin.out
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ ls
data5.bin  data6.bin.out  data8.bin  data.txt  veri
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ file data8.bin
data8.bin: gzip compressed data, was "data9.bin", last modified: Tue Oct 14 09:26:06 2025, max compression, from Unix, original size modulo 2^32 49
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ mv data8.bin data8.gz
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ gunzip data8.gz
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ ls
data5.bin  data6.bin.out  data8  data.txt  veri
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ file data8
data8: ASCII text
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$ cat data8
The password is F05dWfSc0cbaTiH0h8J2eUks2vdTDwAn
bandit12@bandit:/tmp/tmp.dSYwi5nEPd$
```


Level 13 : Burada bir sonraki levelin şifresine ulaşabilmek için sadece bandit 14 kullanıcısının erişebileceği `/etc/bandit_pass/bandit14` dosyasına erişmeye çalıştım. Bunu yaparken anahtar tabanlı kimlik doğrulama yöntemi kullandım. Bu süreçte elde edilen Private Key (Özel Anahtar), sunucuya karşı parolasız bir kimlik ispatı (identity proof) gerçekleştirmemizi sağlamıştır.

~/ssh/ : SSH istemcisi , bir bağlantı isteği gönderirken kimlik bilgilerini öncelikle kullanıcının ana dizindeki gizli .ssh/ klasörüne arar. Bu nedenle, bandit13 sunucusundan aldığımız anahtar verisini kendi Kali Linux bu klasör altına yerleştirdim.

id_rsa: Sistem, .ssh/ klasörü içinde özel olarak id_rsa isimli dosyayı default private key olarak kabul eder. Dosyaya bu ismi vererek, ssh komutuna statik bir parametreyle dosya yolu göstermesine gerek kalmadı.

chmod 600: SSH protokolü, gizli anahatarların başka kişilere erişime açık olmasını güvenlik açığı olarak değerlendirir ve bu anahatarları kullanmayı reddeder. chmod 600 komutuyla sadece dosyanın sahibi veya root okuyabilir şekilde düzenledik.

ssh bandit14@bandit.labs.overthewire.org -p 2220: Sonrasında ise bu komutu çalıştırdık ve istemci ek parametre almamasına rağmen Private Key üzerinden yapılan handshake sayesinde bu anahtarın bandit14 kullanıcısı ile eşleştiğini doğruladı ve parolayı sormadan içeri aldı.

```
want to install supplementary tools. Learn how:
=> https://www.kali.org/docs/troubleshooting/common-minimum-setup/

(Run: "touch ~/.hushlogin" to hide this message)

(sanis@SANIYE-S-LAPTOP)-[~]
$ mkdir -p ~/.ssh

(sanis@SANIYE-S-LAPTOP)-[~]
$ cat > ~/.ssh/id_rsa
-----BEGIN RSA PRIVATE KEY-----
MIIEpAIBAAKCAQEAxkkOE83W2c0T7IWfFc9aPaaQmQDdgzuXCv+ppZHa++buSkN+
gg0tcr7Fw8NLGa5+Uzec2rEg0WmeevB13AIoYp0MZYETq46t+jk9puNwZwIt9XGB
ZufGtZEwwbFWw/vVLNwOXBe4UWStGRWzgPpEeSv5Tb1VjLZIBdGphTIK22Amz6Zb
ThMsiMnyJafEWJ/T8PQO3myS91vUHEuo0MAzoUID4kN0MEZ3+XahyK0HJVq68KsV
ObefXG1vvA3GAJ29kxJaqrFgYnqZryWN7w3CHjNU4c/2Jkp+n8L0SnxAANA+WYA7
jiPyTF0is8uzMLYQ4l1Lzh/8/MpvhCQF8r22dwIDAQABAoIBAQC6dWBjhYE0zjeA
J3j/RWmap9M5zfJ/wb2bfidNpwbB8rsJ4sZIDZQ7XuIh4LfgygoAQSS+bBw3RXvze
pvJt3SmU8hIDuLScjL1VnBY5pY7Bju8g8aR/3FyjyNAqx/TLfzLLYfOu7i9Jet67
xAh0tONG/u8FB5I3LAI2Vp60viwvdWeC4n0xCthLdpUPKNLA8rmMMVRTKQ+7T2VS
nXmwYckKUcUgzoVSpINzaS0zUDypdpY2+tRH3MQa5kqN1YKjvF8RC47wo0YCktsD
o3FFpGNFec9Taa3Msy+DfQQhHKZFkiL3bJDONtmrVvtYK40/yeU4aZ/HA2DQzwhe
o11AfieHAoGBAOvJosBkm7sbLK+n4IEWPxs8s0mhPnTDUy5WGrpScrX0msVIBUF
laL3ZGLx3xCIwtCnEuCB9DvN2HZkupc/h6hTKUYLqXuyLD8njTrbRhLgbC9QrKrS
M1F2fstVqPtZDLDMwjNR04xHA/fKh8bXXyTMqOHNJTHHNhb3McduURjAoGBANKU
1hqfnw7+aXncJ9bjysr1ZWbQOE5Nd8AFgfwaKuGTTVX2NsUQNcmWdOp+wFak40JH
PKWkJndBG+ex0H9JNQsTK3X5PBMAS8AfX0GrKeuwKWA6erytVTqjOfLYcdp5+z9s
8DtVCxDuVsM+i4X8UqIGOlvgbtKEVokHPFXPlq/dAoGACHg5YX7WEehCGCYTZp0+
xysX8ScM2qS6xuZ3MQUWAxUWkh7NGZvhe0sGy9iOdANzwKw7mUUFViacMR/t54W1
GC83sOs3D7n5Mj8x3Nd08xFit7dT9a245TvaoYQ7KgmpqSg/SCKCW4c3eiLava+J
3btnJeSIU+8ZXq9XjPRpKWUCGYA7z6Li0QKXNeXH3qHXcnHok855maUj5fJNPbY
iDkyZ8ySF8GLcfsky8Yw6fwCqfG3zDrohJ5l9JmEsBh7SadkwsZhvecQcS9t4vby
9/8X4js0P8ibfcKS4nBP+dT81kkkg5Z5MohXBORA7Vwx+ACohcDEkprsq+w32xeD
qT1EvQKBgdQDKm8ws2ByvSUvs9GjTilCajFqLJOeVYZRPAY6f++Gv/UVfAPV4c+S0
kAWpXbv5tbkkzbS0eaLPTKgLzavXtQoTtkwrjpolHKIHUz6Wu+n4abfAIRFubOdN
/+aLoRQ0yBDRbdXMszN/jvY44eM+xRLdRVyMmdPtP8belRi2E2aEzA==
-----END RSA PRIVATE KEY-----

(sanis@SANIYE-S-LAPTOP)-[~]
$ chmod 600 ~/.ssh/id_rsa

(sanis@SANIYE-S-LAPTOP)-[~]
$ ssh bandit14@bandit.labs.overthewire.org -p 2220

      _-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-_-
      |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |
      |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |
      * gef (https://github.com/hugsy/gef) in /opt/gef/
      * pwndbg (https://github.com/pwndbg/pwndbg) in /opt/pwndbg/
      * gdbinit (https://github.com/gdbinit/Gdbinit) in /opt/gdbinit
      * pwntools (https://github.com/Gallopsled/pwntools)
      * radare2 (http://www.radare.org/)

--[ More information ]--

For more information regarding individual wargames, visit
http://www.overthewire.org/wargames/

For support, questions or comments, contact us on discord or IRC

Enjoy your stay!

bandit14@bandit:~$ cat /etc/bandit_pass/bandit14
MU4VWeTyJk8ROof1qqmcBPALh7LDCPVs
bandit14@bandit:~$
```

Level 14: Bir sonraki seviyenin şifresi, mevcut seviyenin şifresini localhost üzerindeki 30000 numaralı porta göndererek alınır.

nc localhost 30000: Bu komut ile localhost 30000 numaralı porta bir TCP bağlantısı başlatılmıştır. Netcat, bu noktada istemci rolünü üstlenerek hedef port ile açık bir veri kanalı oluşturmuştur. Bağlantı sağlandıktan sonra, bandit14 kullanıcısı olarak elde edilen statik parola bu açık kanala yapıştırılarak gönderilmiştir. Netcat, terminalden girilen bu veriyi Raw TCP (ham veri) paketleri halinde sunucuya iletmış , sunucuda parolayı doğrulayarak level 15 in parolasını vermiştir.

```
In addition, the exelstack tool can be used to flag the stack as
executable on ELF binaries.

Finally, network-access is limited for most levels by a local
firewall.

--[ Tools ]--

For your convenience we have installed a few useful tools which you can
in the following locations:

* gef (https://github.com/hugsy/gef) in /opt/gef/
* pwndbg (https://github.com/pwndbg/pwndbg) in /opt/pwndbg/
* gdbinit (https://github.com/gdbinit/Gdbinit) in /opt/gdbinit/
* pwntools (https://github.com/Gallopsled/pwntools)
* radare2 (http://www.radare.org/)

--[ More information ]--

For more information regarding individual wargames, visit
http://www.overthewire.org/wargames/

For support, questions or comments, contact us on discord or IRC.

Enjoy your stay!

bandit14@bandit:~$ nc localhost 30000
MU4VWeTyJk8ROof1qqmcBPALh7lDCPvS
Correct!
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo
```

Level 15: Bir sonraki seviyenin şifresi, mevcut seviyenin şifresini SSL/TLS şifrelemesi kullanarak localhost'taki 30001 numaralı porta göndererek alınabilir .

```
* pwntools (https://github.com/Gallopsled/pwntools)
* radare2 (http://www.radare.org/)

--[ More information ]--

For more information regarding individual wargames, visit
http://www.overthewire.org/wargames/

For support, questions or comments, contact us on discord or IRC.

Enjoy your stay!

bandit15@bandit:~$ openssl s_client -connect localhost:30001
CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 CN = SnakeOil
verify error:num=18:self-signed certificate
verify return:1
depth=0 CN = SnakeOil
verify return:1
---
Certificate chain
 0 s:CN = SnakeOil
  i:CN = SnakeOil
  a:PKEY: rsaEncryption, 4096 (bit); sigalg: RSA-SHA256
  v:NotBefore: Jun 10 03:59:50 2024 GMT; NotAfter: Jun  8 03:59:50 2034 GMT

Protocol : TLSv1.3
Cipher    : TLS_AES_256_GCM_SHA384
Session-ID: 46DDDD585B7E98E7983507BEC303AD4DEFD41EAEEB83AA4C8651B5F2A8736564
Session-ID-ctx:
Resumption PSK: 1781F42DF453B9FE8B4E2413B74298681E07D417A7C54C2CAA6E39A34F25019EDE4
D5D43B0A9162DCC2F49F6488BB775
PSK identity: None
PSK identity hint: None
SRP username: None
TLS session ticket lifetime hint: 300 (seconds)
TLS session ticket:
0000 - 59 18 5f 35 33 8f 4a e0-a9 7c 7b 75 09 a3 92 1e   Y._53.J..|{u...
0010 - 17 4a a3 0b 4c dd 3c a4-aa 9b 33 70 9b fc a0 98   .J..L.<...3p...
0020 - d8 89 ad b0 09 6b 0c 93-11 1c 9a 05 07 84 32 0f   .....k.....2.
0030 - 94 cb 32 f2 74 f3 c5 d8-e3 0f ef 74 a2 cc e3 8d   ..2.t.....t...
0040 - 47 c2 43 d7 00 8e e5 27-ae ca 4c f0 46 34 14 cb   G.C.....'.L.F4..
0050 - 4a 27 b9 2e 09 3a 95 e9-c6 bd e3 1e 90 c0 6f 78   J'.....ox
0060 - 1e 01 77 8a a5 83 ef 6f-7c 39 10 3f c2 64 64 51   ..w....o|9.?.ddQ
0070 - 50 47 76 43 17 ba d2 df-6b af fd 82 94 70 dd 69   PGvC....k....p.i
0080 - 44 a0 48 f6 cc 05 9a c1-82 e1 bc 0b 01 0f 40 ea   D.H.....@.
0090 - 80 e2 7f 07 18 4b 39 0b-78 6b 36 ac 00 0c 24 d3   .....K9.xk6...$.
00a0 - db 17 f3 f0 1b eb 0d 64-b7 d0 8c 71 25 51 25 32   .....d...q%Q%2
00b0 - a3 1a 5c ad a0 8f 10 4f-4c 0f 15 dd d2 4b 3d 19   ..\....OL....K=.
00c0 - 7f a0 e1 09 6b 13 a1 77-b6 0d 3f 4b ae d0 17 1d   ....k..w..?K....
00d0 - af 44 f6 7f 4c 09 55 ba-37 24 e5 14 6a b1 1b 48   .D..L.U.7$.j..H

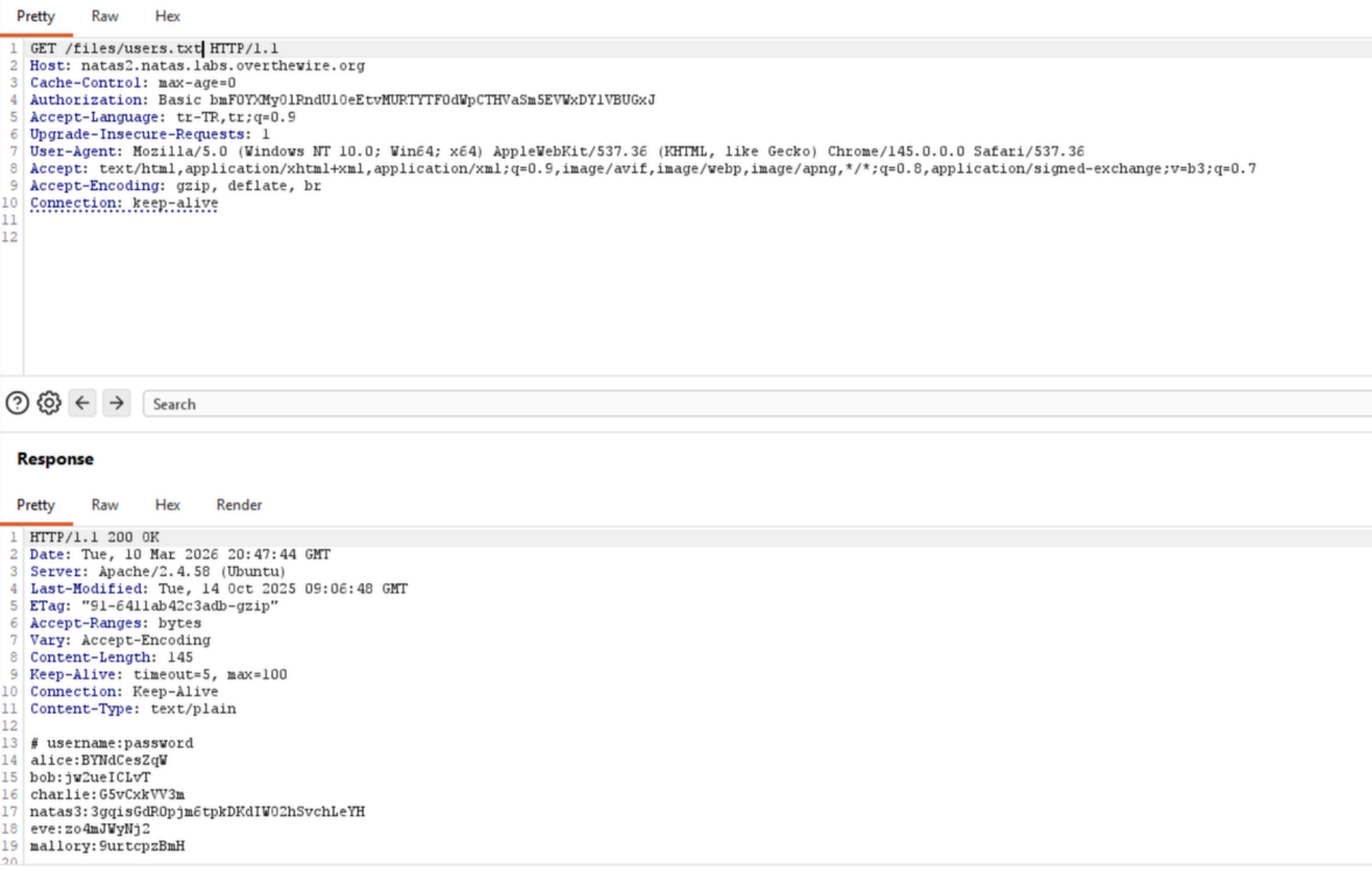
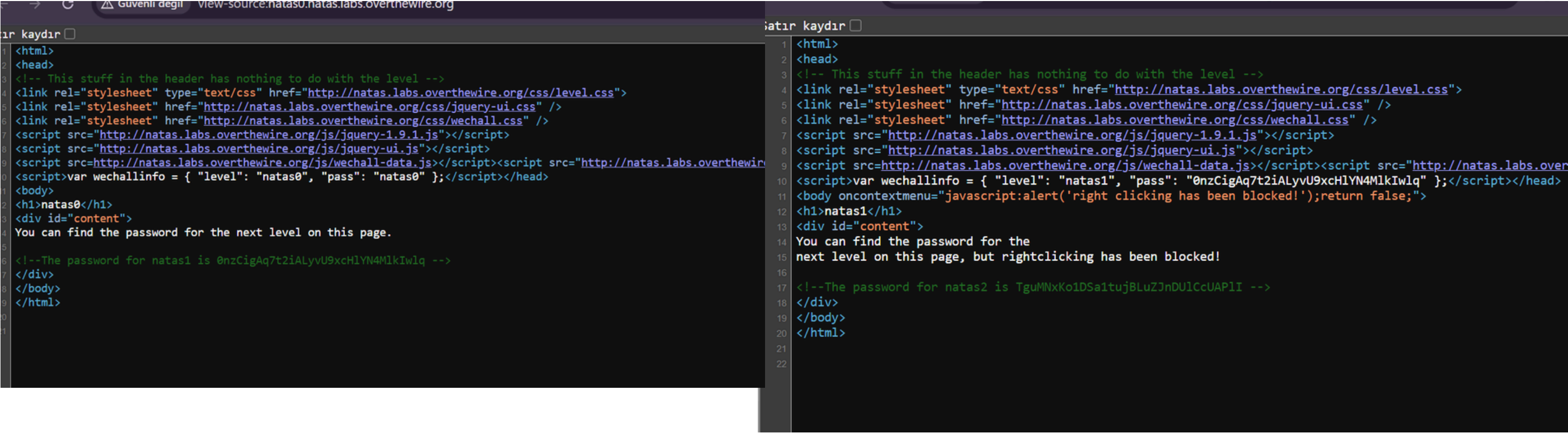
Start Time: 1773155199
Timeout    : 7200 (sec)
Verify return code: 18 (self-signed certificate)
Extended master secret: no
Max Early Data: 0

---
read R BLOCK
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo
Correct!
kSkvUpMQ7lBYyCM4GBPvCvT1BfWRy0Dx

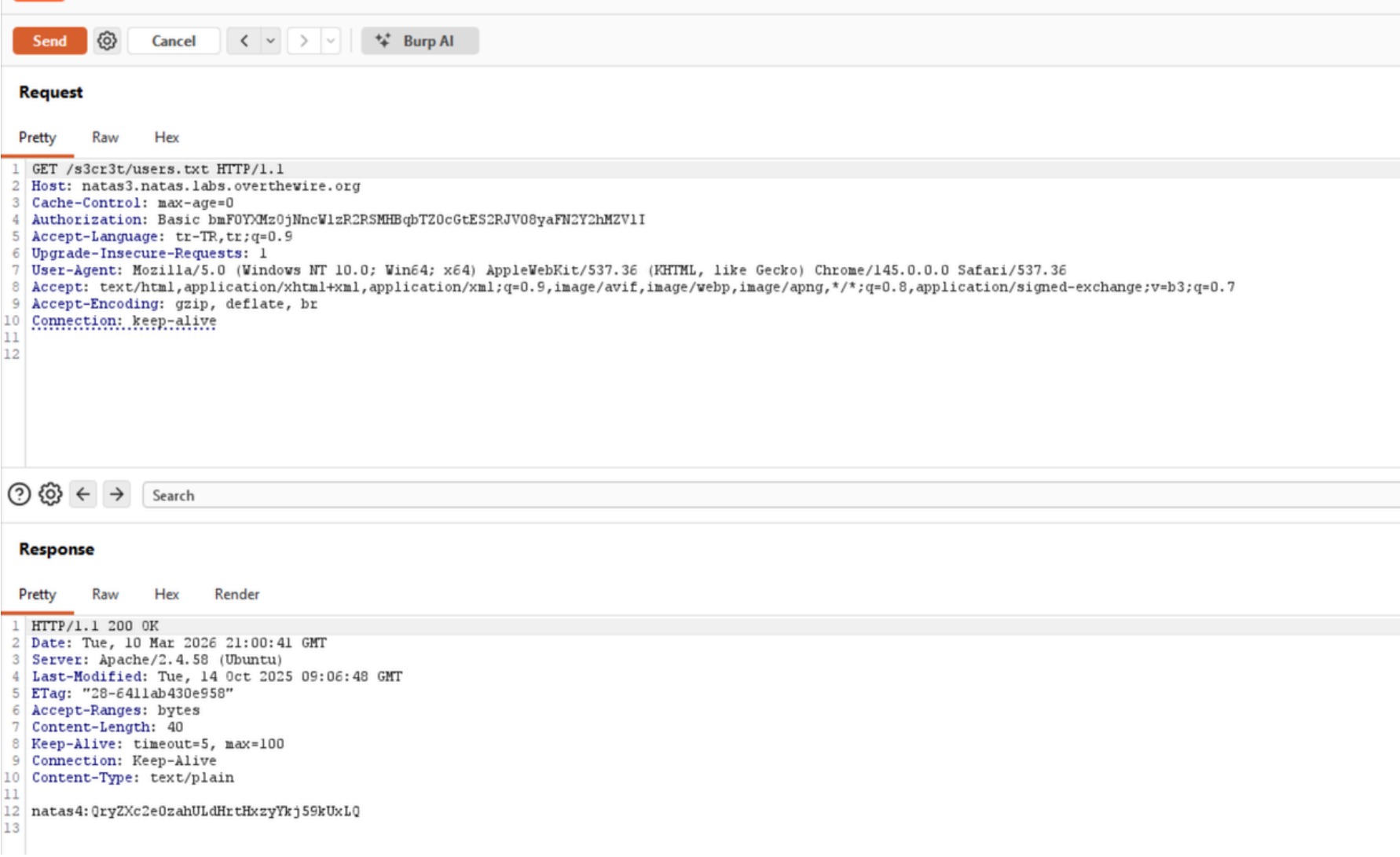
closed
bandit15@bandit:~$
```

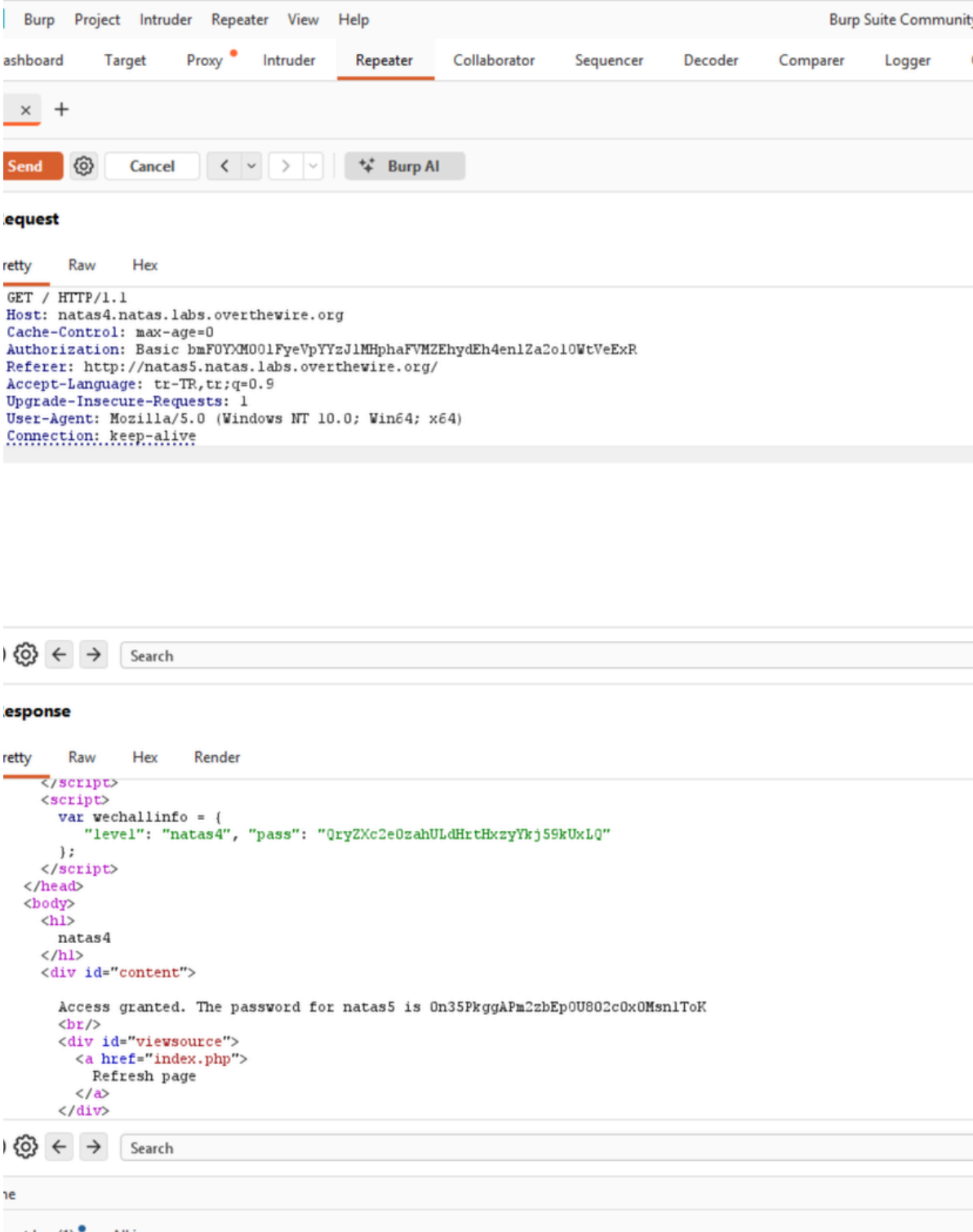

Cephe 2: Web Mantık Avcısı (Sunucu Tarafı)

Natas 0 ve 1 Zafiyet: Güvensiz HTML yorum satırları : Şifre, kaynak kodda `` içinde unutulmuş. CTRL+U ile kaynak kod okunarak şifre alındı.



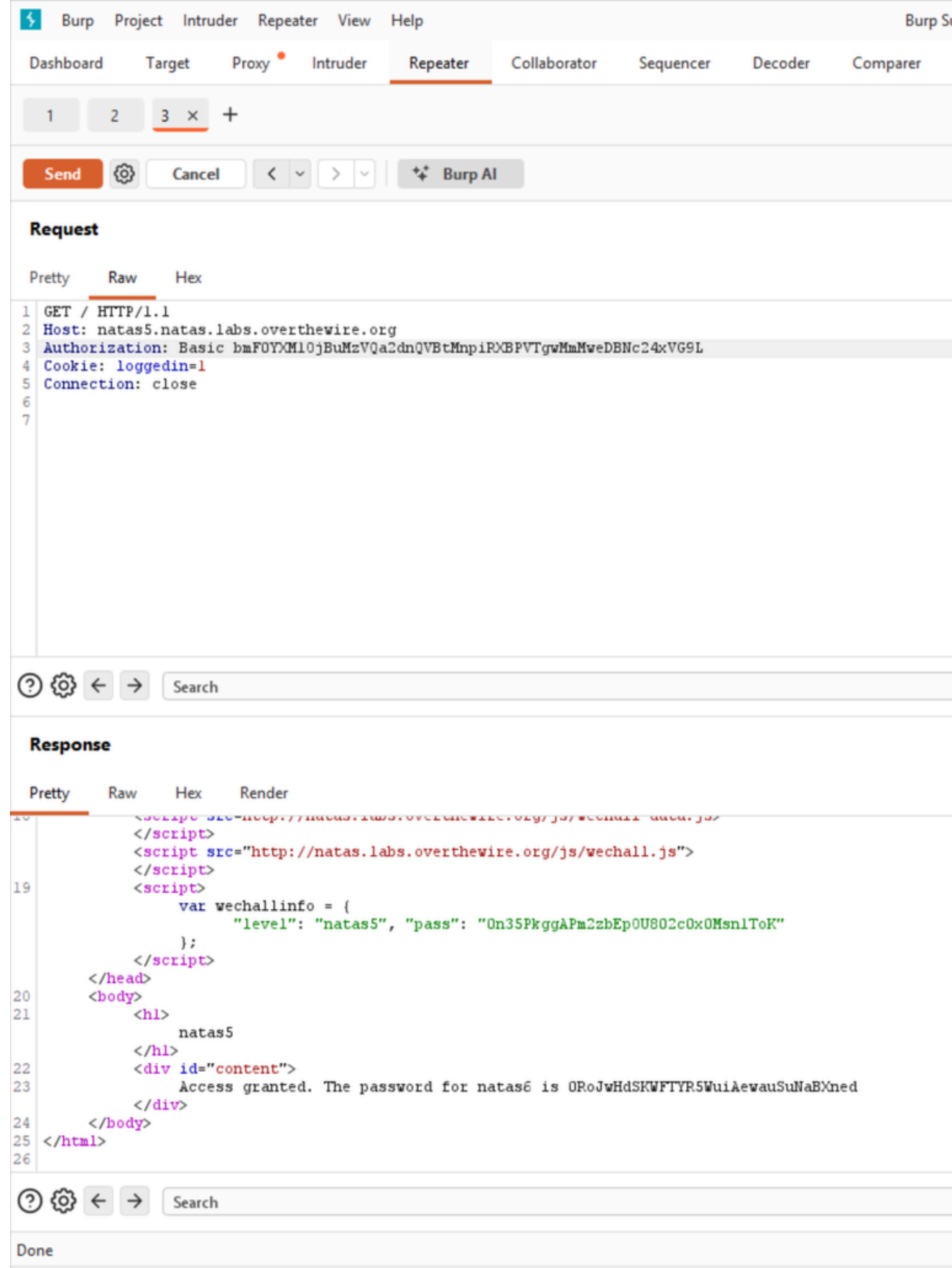
Natas 2 Zafiyet: Yanlış yapılandırılmış sunucu dizini /files/ dizininin içeriği herkese açık bırakılmış. /files/users.txt dosyasına gidilerek şifre sızdırıldı.



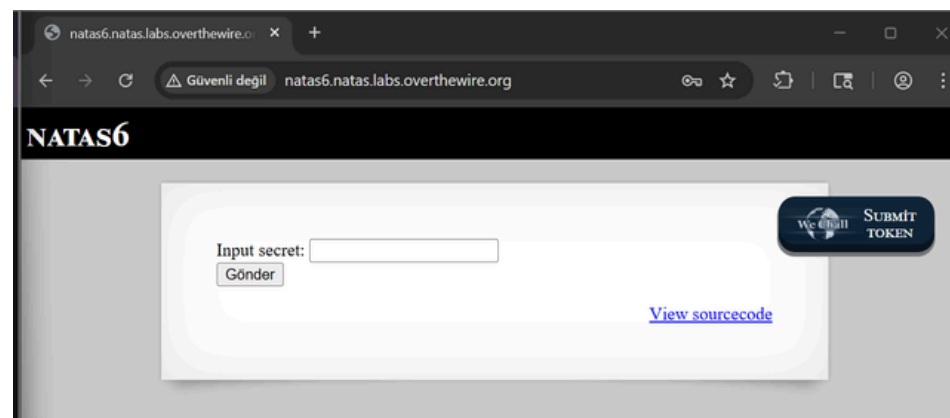
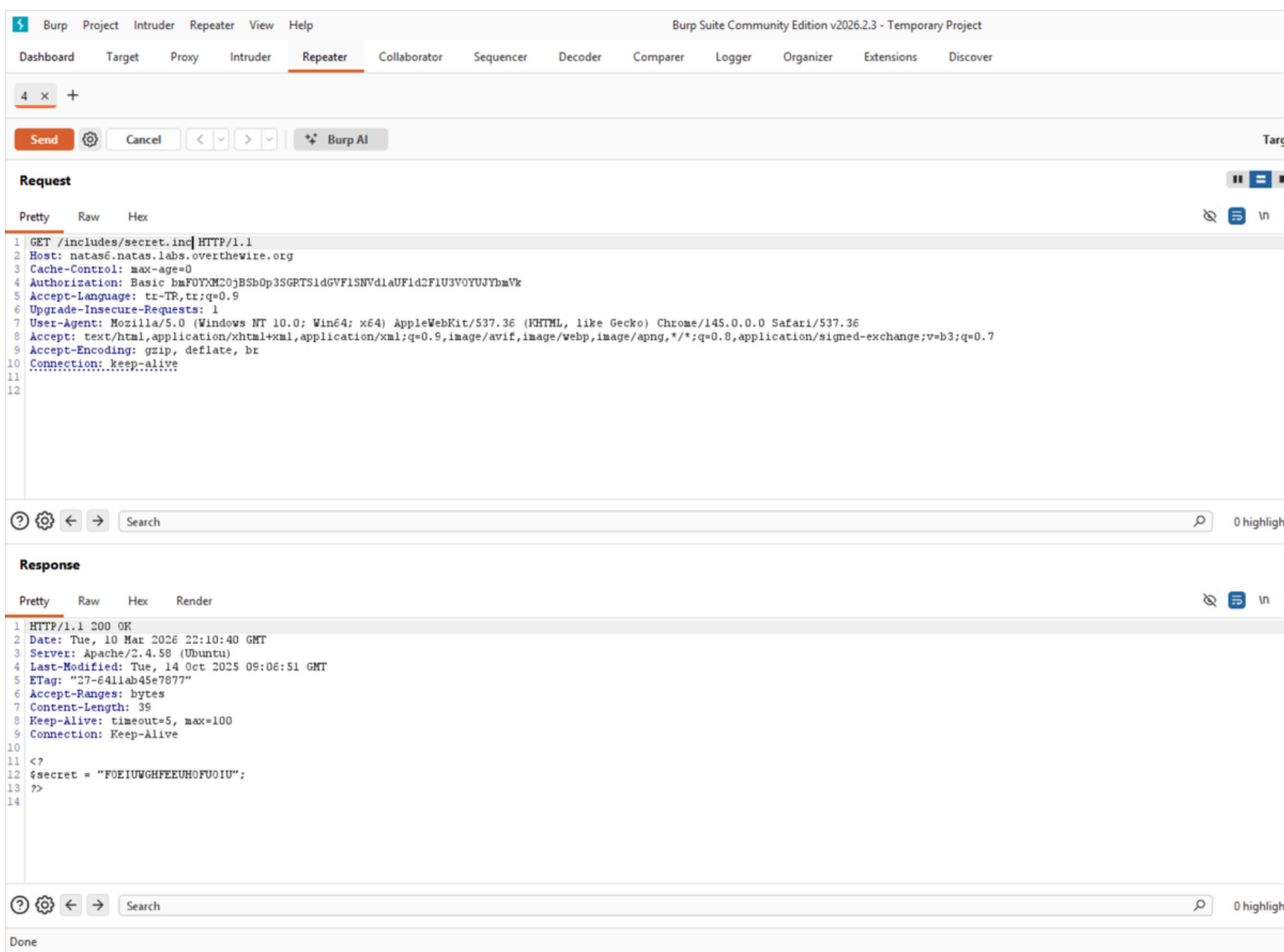


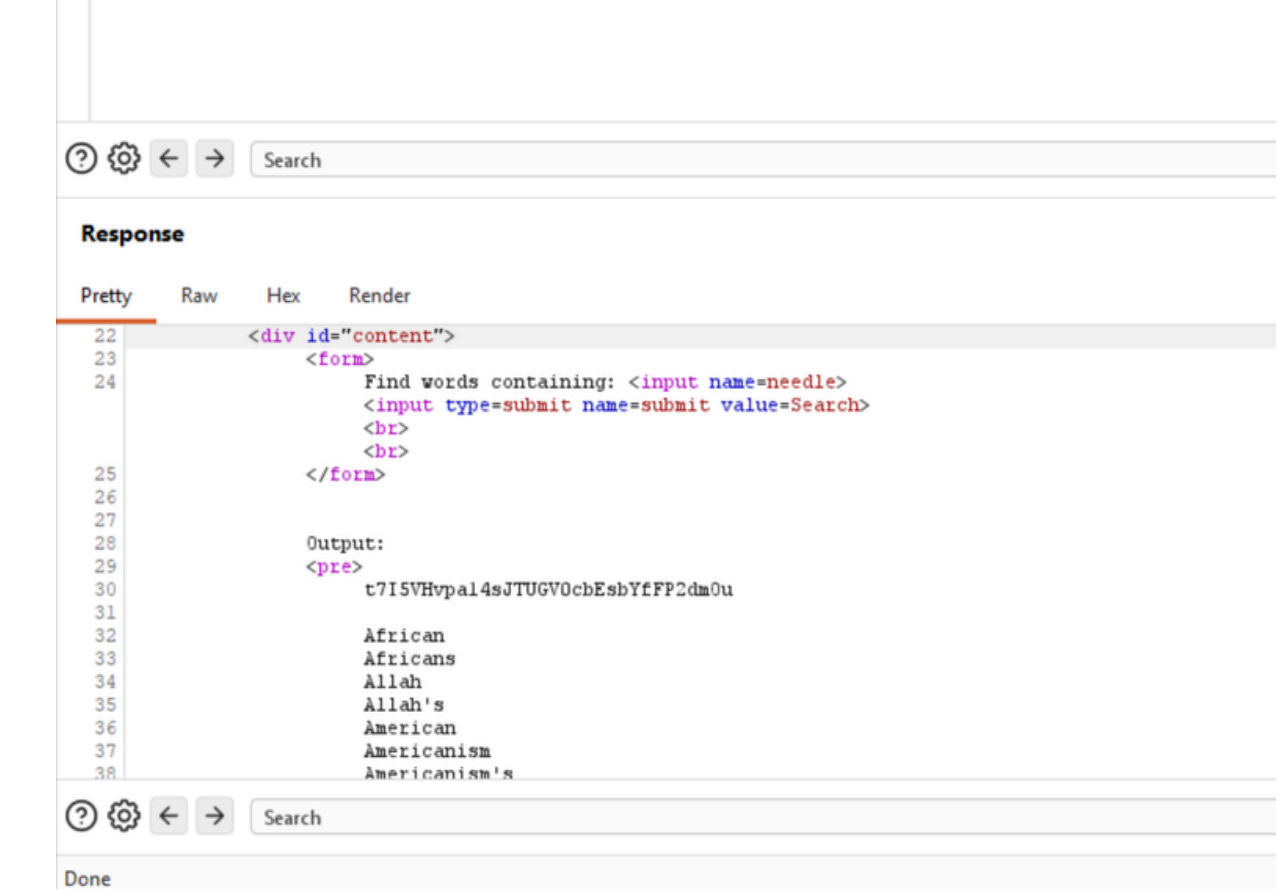
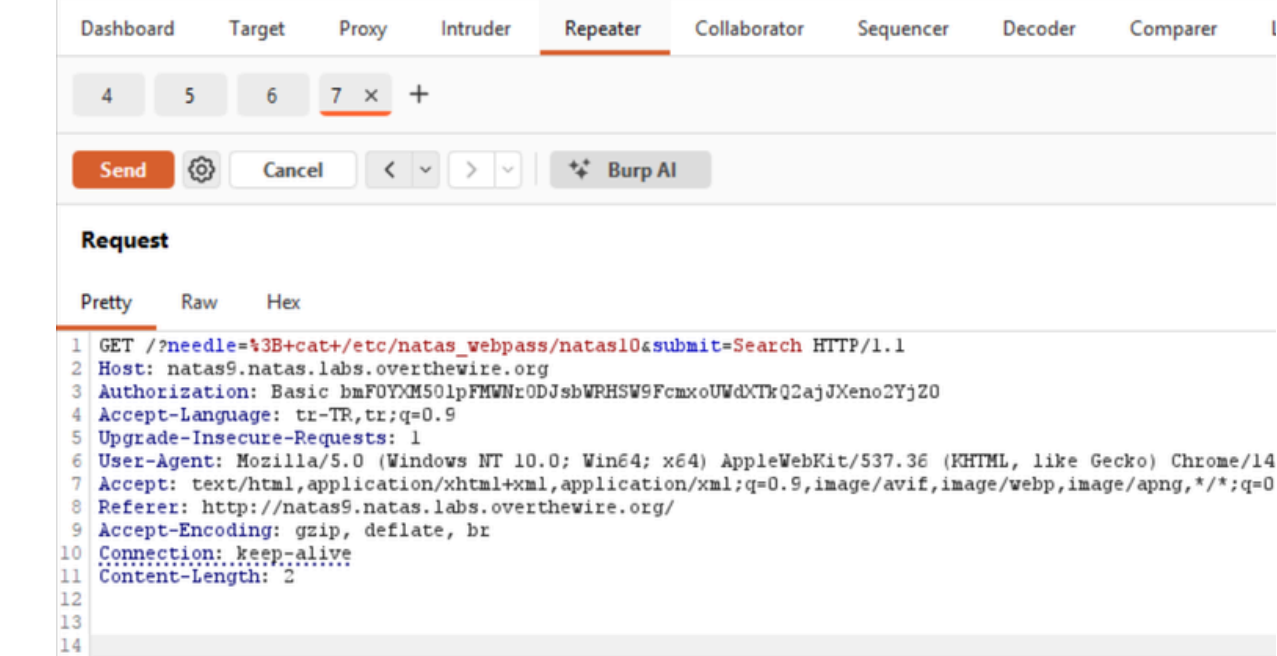
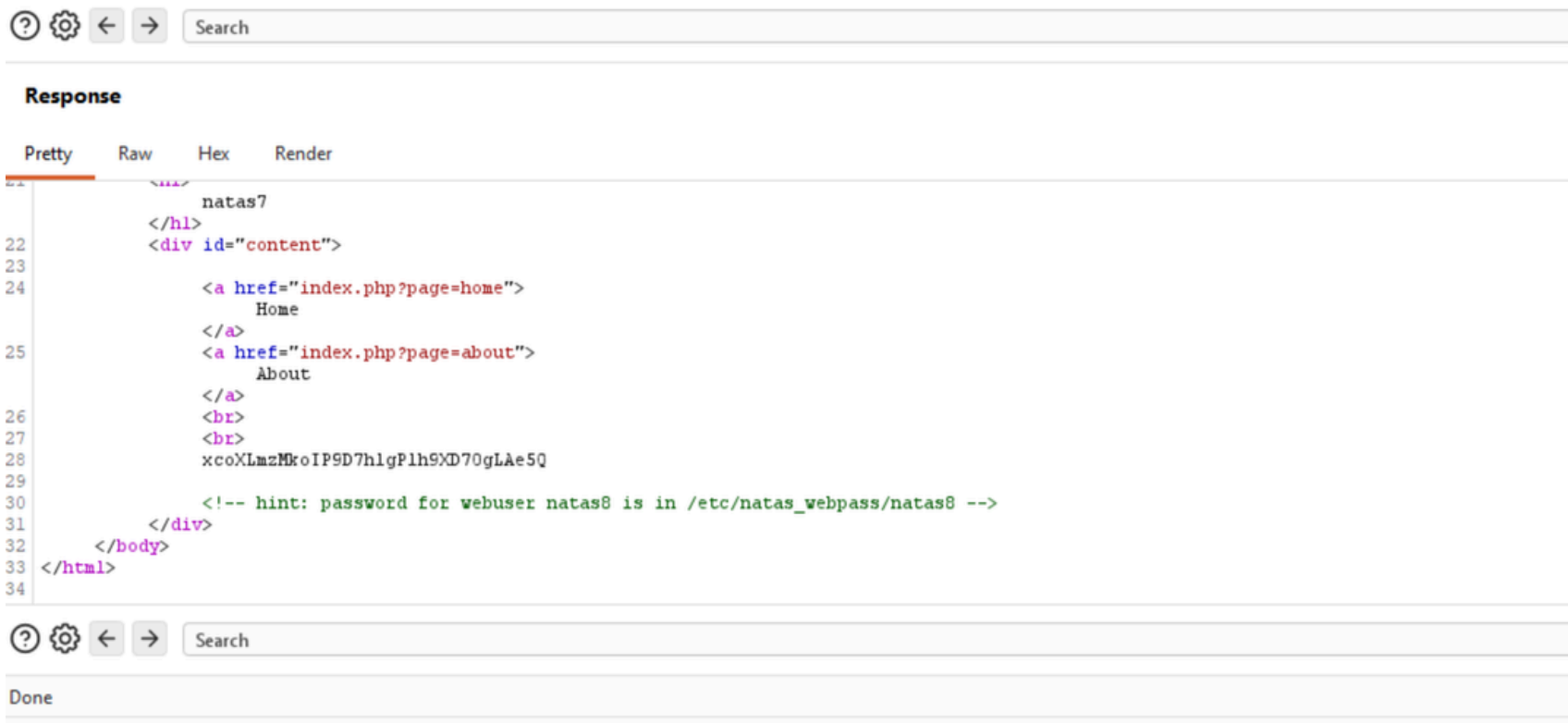
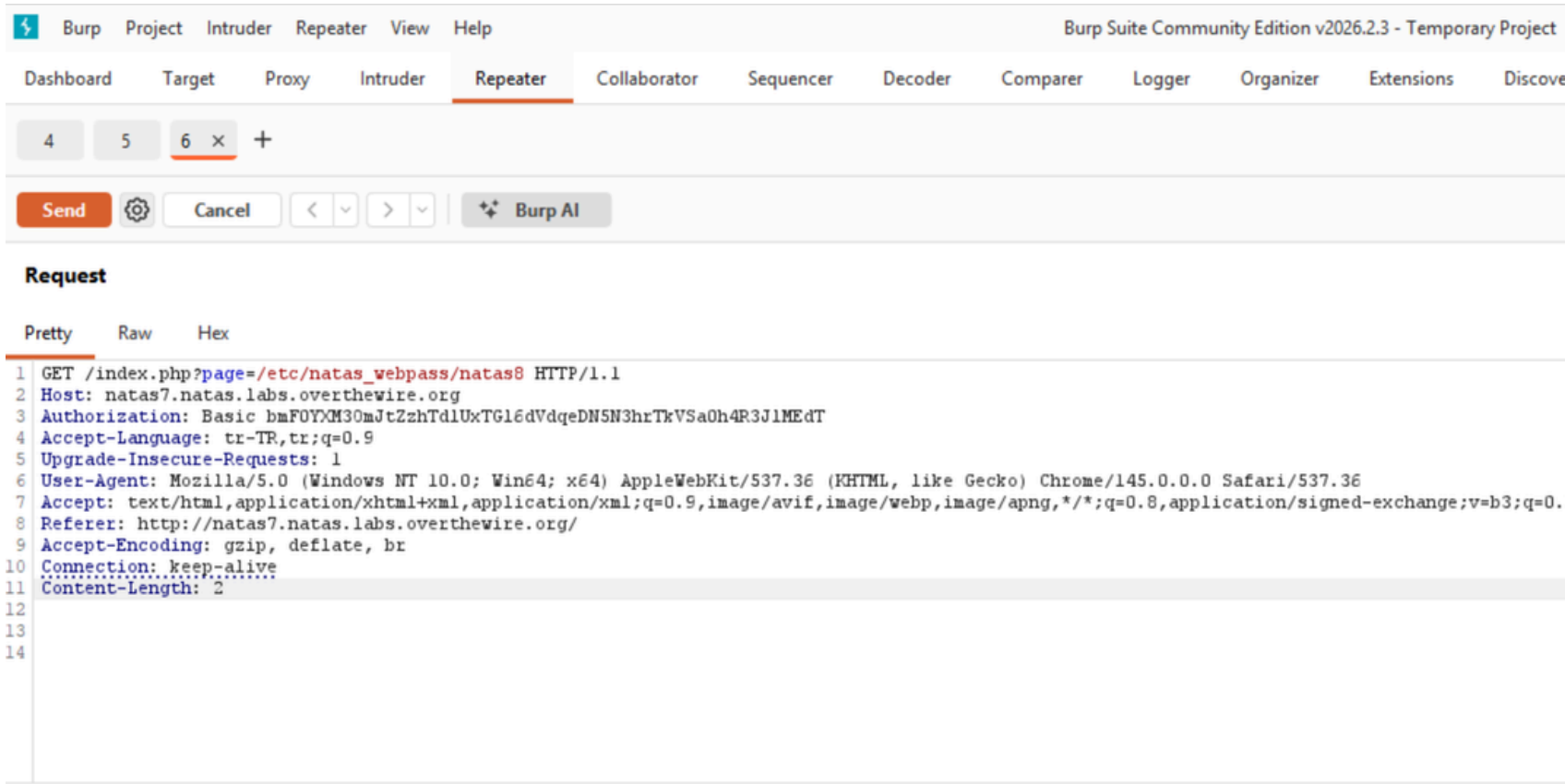
Natas 4 Zafiyet Türü: Güvensiz Kaynak Kontrolü (Broken Access Control).

Sunucu, isteğin sadece natas5 sayfasından gelmesi durumunda şifreyi vermektedir. Bu kontrol Referer başlığı üzerinden yapılmaktadır. Burp Suite Proxy ile istek yakalanmış, Referer başlığı manuel olarak <http://natas5.natas.labs.overthewire.org/> olarak değiştirilmiştir.



Natas 5 Zafiyet Türü: Parametre Karıştırma (Parameter Tampering). Sayfada "You are not logged in" mesajı görülmüştür. Burp Suite ile çerezler incelendiğinde loggedin=0 değeri tespit edilmiştir. Çerez değeri loggedin=1 olarak değiştirilerek sunucu tarafındaki oturum kontrolü baypas edilmiştir.



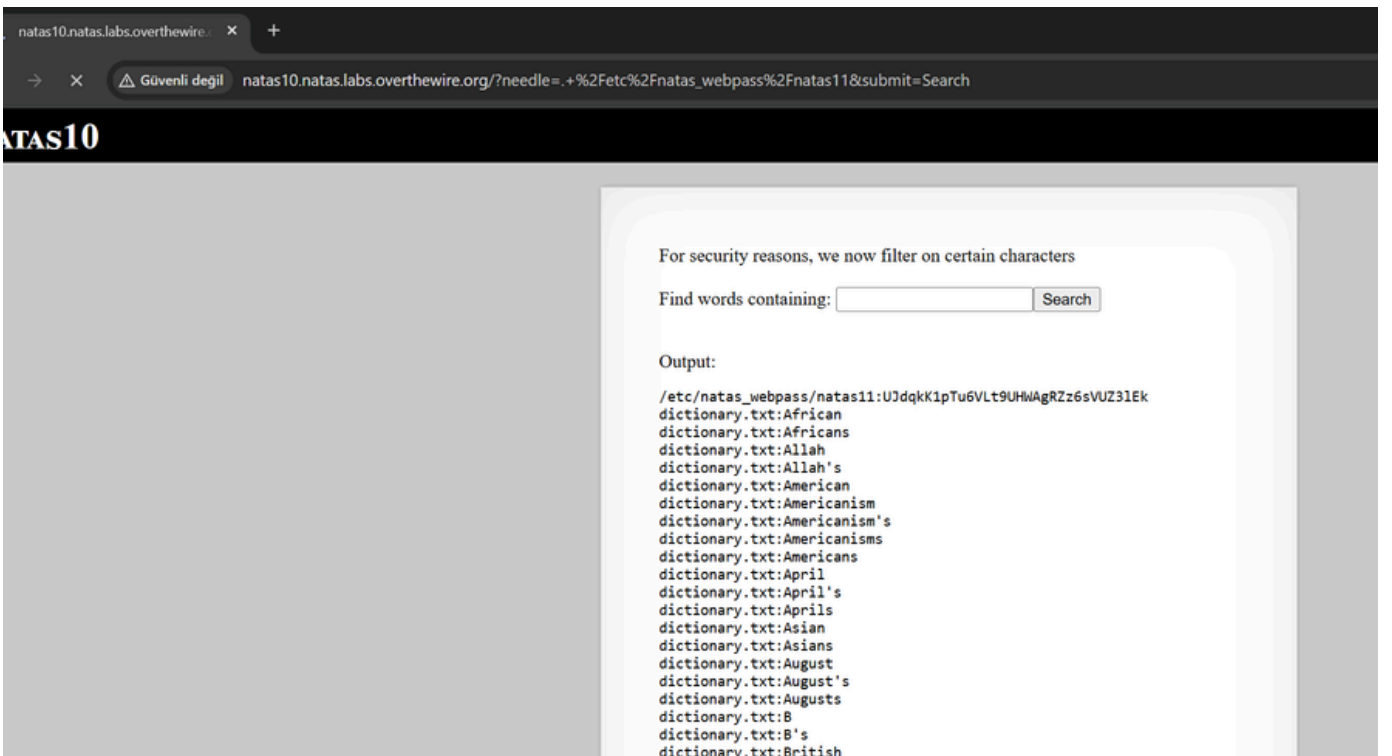


Natas 7 Zafiyet: Yerel dosya dahil etme açığı.
?page= parametresi sunucu dosyalarını doğrudan çağırabiliyor.
/etc/natas_webpass/natas8 yolu verilerek sistem dosyası okundu.

Natas 8 Zafiyet: Geri döndürülebilir şifreleme algoritması.
Şifre; Base64, Reverse ve Hex işlemleriyle kodlanmış. Burp Decoder ile işlemler tersine uygulanarak şifre çözüldü.

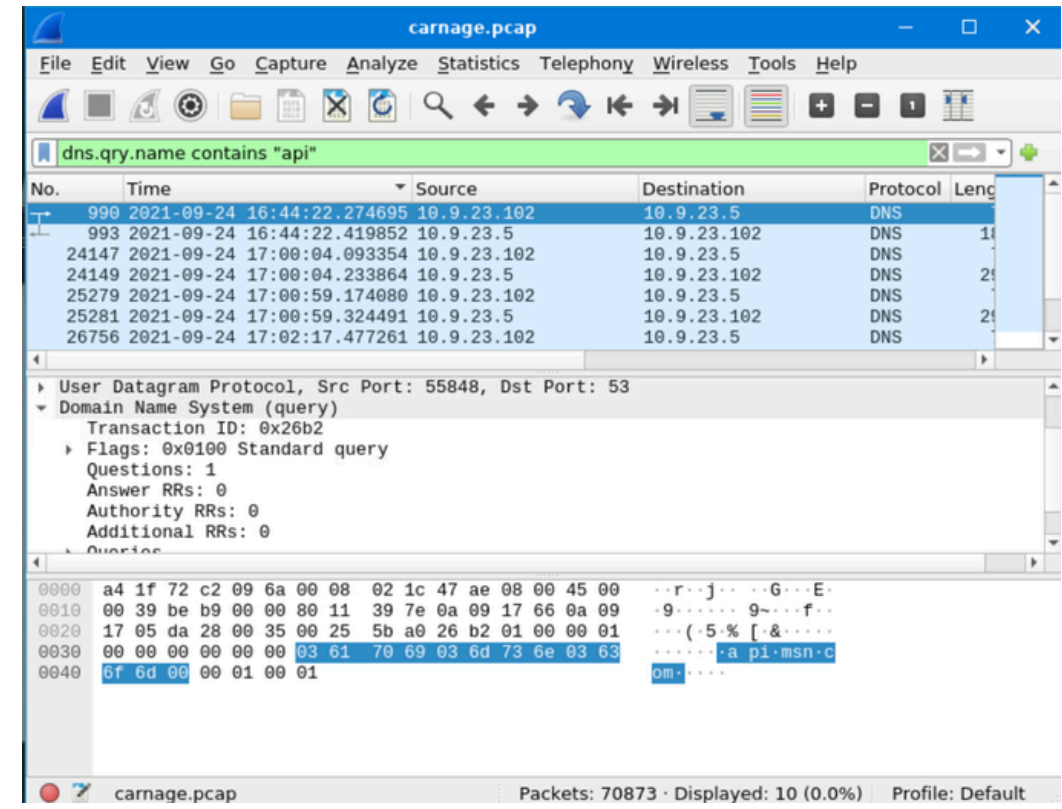
Natas 9 Zafiyet: Girdi doğrulaması eksikliği.
passthru() fonksiyonu kullanıcı verisini doğrudan terminale aktarıyor. ; cat /etc/natas_webpass/natas10 komutu enjekte edilerek dosya okundu.

Natas 10 Zafiyet: Yetersiz karakter filtreleme (Blacklisting)
; yasaklanmış ancak grep komutunun parametre yapısı korunmuş. . /etc/natas_webpass/natas11 payload'u ile filtre aşılp şifre sızdırıldı

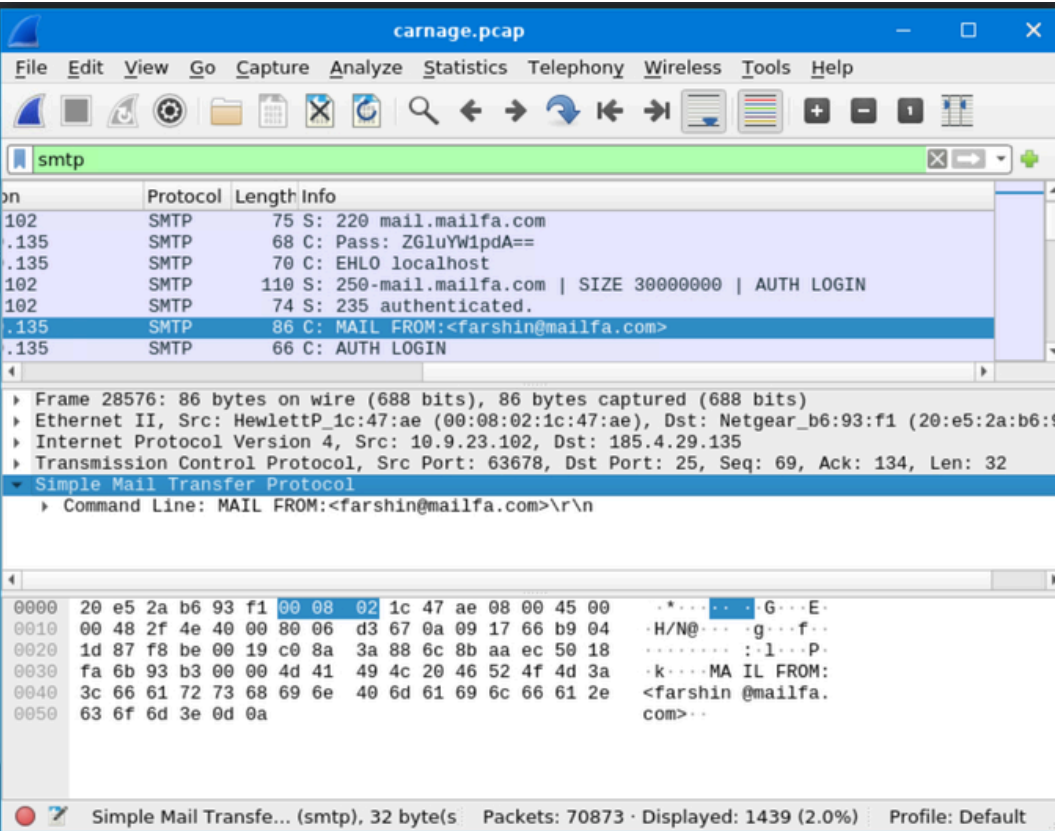


IP kontrolü için DNS sorgusunun gerçekleştiği tarih ve saat nedir? : 2021-09-24 16:44:22

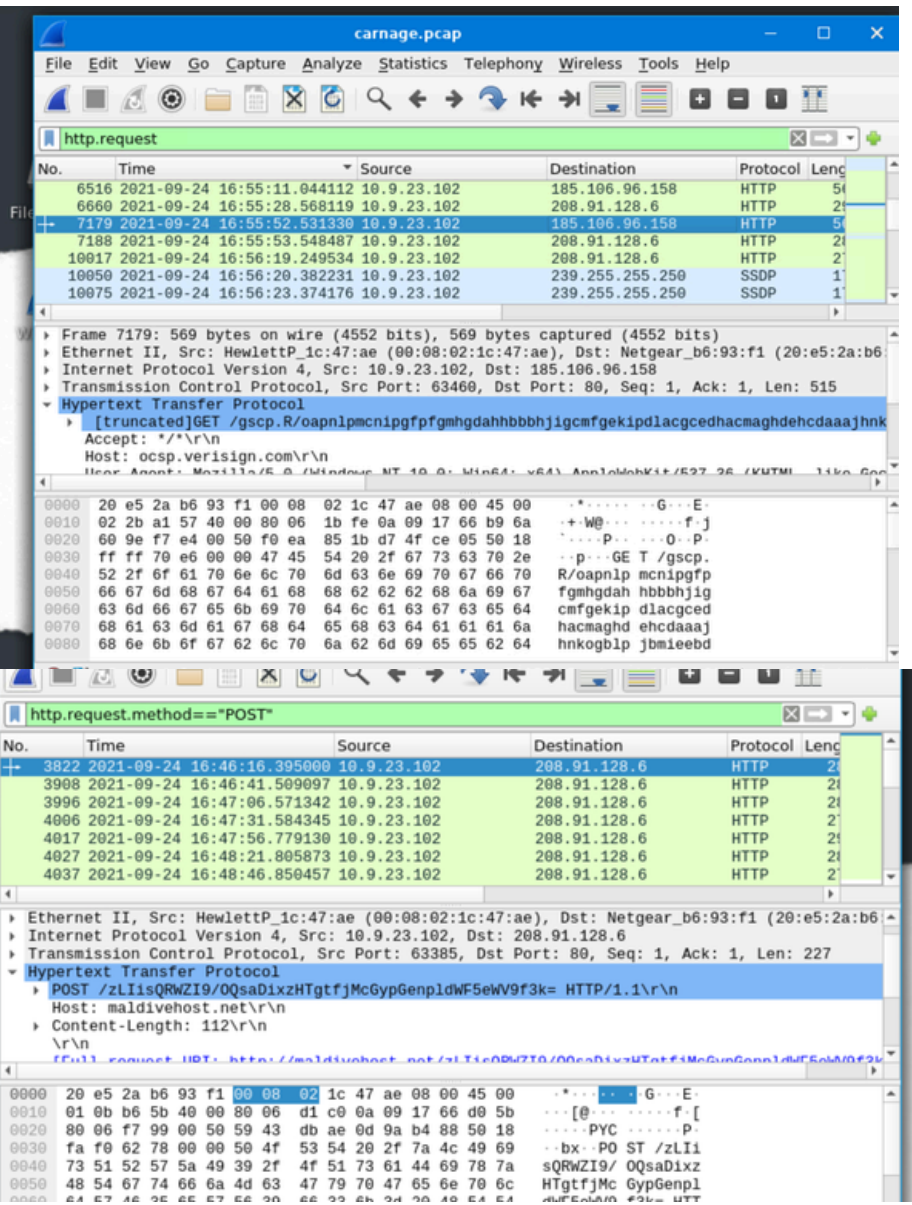
Önceki sorudaki DNS sorgusunda yer alan alan adı neydi?: api-msn-com



Trafikte gözlemlenen ilk "MAIL FROM" adresi neydi?: farshin@mailfa.com SMTP trafiği için kaç paket gözlemlendi?: 1439



Cobalt Strike sunucularının iki IP adresi nedir? : 185.106.96.158, 208.91.1 Önceki sorudaki ilk Cobalt Strike IP adresinin Host başlığı nedir? : oosp.verisign.com



Bölüm C : Av Mevsimleri Saha Adımları

Cephe 1: Hedef Seçimi ve Keşif (Recon Haritası)

Hedefim Bugcrowd üzerinden Redbull şirketi oldu.

partnerid.admin.redbull.com
ontrack-q.redbull.com
planogram-d.redbull.com subdomainlerini inceledim.

```
sales.redbull.com
planogram-d.redbull.com
rbeurnxt04.infra.redbull.com
infonet.redbull.com
origin.microsites05.redbull.com
[INF] Found 1170 subdomains for redbull.com in 9 seconds 552 milliseconds

--(sanis@SANIYE-S-LAPTOP)~--
$ cat redbull_listesi.txt | httpx-toolkit -sc -title -mc 200

v1.1.5

projectdiscovery.io

Use with caution. You are responsible for your actions.
Developers assume no liability and are not responsible for any misuse or damage.
https://addons-thailand.redbull.com [200] [Red Bull Media House Webhosting]
https://abp.redbull.com [200] [Red Bull - Artist Bonus Program]
https://addons-redbullrookiescup.redbull.com [200] []
https://addons-redbullsymphonic.redbull.com [200] [Red Bull Media House Webhosting]
https://app.redbull.com [200] [Red Bull Media House Webhosting]
https://athleteapp-mgmt-d.redbull.com [200] [RBA Team Room]
https://athleteapp-mgmt.redbull.com [200] [RBA Team Room]
https://athleteapp-mgmt-q.redbull.com [200] [RBA Team Room]
https://bilan2019.redbull.com [200] [Vote pour les artistes qui ont marqué le rap en 2019]
https://bulldrive.redbull.com [200] []
https://bulldrivearchive.redbull.com [200] []
https://changeit-d.redbull.com [200] [MyWorkID]

https://navigator-q.redbull.com [200] [Red Bull Navigator]
https://ontrack-q.redbull.com [200] [Red Bull OnTrack]
https://ontrack.redbull.com [200] [Red Bull OnTrack]
https://origin.microsites03.redbull.com [200] [Red Bull Media House Webhosting]
https://origin.microsites01.redbull.com [200] [Red Bull Media House Webhosting]
https://origin.microsites.redbull.com [200] [Red Bull Media House Webhosting]
https://origin.microsites02.redbull.com [200] [Red Bull Media House Webhosting]
https://origin.microsites04.redbull.com [200] [Red Bull Media House Webhosting]
https://origin.microsites05.redbull.com [200] [Red Bull Media House Webhosting]
https://partnerid.admin.redbull.com [200] [Partner ID - Admin]
https://partnerid-q.redbull.com [200] [Partner ID]
https://partnerid-d.redbull.com [200] [Partner ID]
https://planogram.redbull.com [200] [Planogram - Red Bull]
https://portaltoro.redbull.com [200] [Portal Toro]
https://partnerid.redbull.com [200] [Partner ID]
https://punchlines.redbull.com [200] [Votez et éliez les meilleures punchlines de 2019]

https://qm.redbull.com [200] []
https://qdrive.redbull.com [200] []
https://planogram-d.redbull.com [200] [Planogram - Red Bull]
https://psapp.redbull.com [200] [PS APP]
https://redbullrapduellquiz.redbull.com [200] [Red Bull Rap Duell Quiz]
https://sap.redbull.com [200] [Red Bull Media House Webhosting]
https://stage-web01093.microsites01.redbull.com [200] [Red Bull Media House Webhosting]
https://stage-web02081.microsites02.redbull.com [200] [Red Bull Media House Webhosting]
https://stage-web03014.microsites03.redbull.com [200] [Red Bull Media House Webhosting]
https://stage-web02047.microsites02.redbull.com [200] [Red Bull Media House Webhosting]
https://stage-web03074.microsites03.redbull.com [200] [Red Bull Media House Webhosting]
https://stage-web01018.microsites01.redbull.com [200] [Red Bull Media House Webhosting]
https://stage-web04013.microsites04.redbull.com [200] [Red Bull Media House Webhosting]
https://tabs.redbull.com [200] [Red Bull Media House Webhosting]
https://videos.redbull.com [200] [Red Bull Media House Webhosting]
https://web01078.microsites01.redbull.com [200] [Red Bull Media House Webhosting]
https://web02030.microsites02.redbull.com [200] [Red Bull Media House Webhosting]
https://web02056.microsites02.redbull.com [200] [Red Bull Media House Webhosting]
https://web02099.microsites02.redbull.com [200] [Red Bull Media House Webhosting]
https://web02090.microsites02.redbull.com [200] [Red Bull Media House Webhosting]
https://web03014.microsites03.redbull.com [200] [Red Bull Media House Webhosting]
https://web03015.microsites03.redbull.com [200] [Red Bull Media House Webhosting]
https://web03045.microsites03.redbull.com [200] [Red Bull Media House Webhosting]
https://web04114.microsites04.redbull.com [200] [Red Bull Media House Webhosting]
https://web04071.microsites04.redbull.com [200] [Red Bull Media House Webhosting]
https://web04053.microsites04.redbull.com [200] [Red Bull Media House Webhosting]
https://wildcard.microsites.redbull.com [200] [Red Bull Media House Webhosting]
https://www.stage-web01018.microsites01.redbull.com [200] [Red Bull Media House Webhosting]

--(sanis@SANIYE-S-LAPTOP)~--
```

Hedef sistemin saldırı yüzeyini haritalandırmak amacıyla kullanılan dirsearch aracı, web sunucusu üzerinde dışarıdan doğrudan erişilemeyen gizli dizinlerin keşfini sağlamıştır.

Subdomain 1: partnerid.admin.redbull.com üzerinde yaptığım dirsearch taramasıyla, normalde gizli kalması gereken soap ve manifest.json gibi kritik dizinlerin dışarıya açık olduğunu (HTTP 200) tespit ettim. Bu durum, admin panelinin teknik mimarisini ve API servislerini doğrudan ifşa ettiği için saldırganlara sızma öncesi çok değerli bilgiler sunan ciddi bir güvenlik zayıflığıdır. Özellikle yönetim odaklı bir sunucuda bu servislerin erişilebilir olması, yetkisiz veri çekme ve hedefli saldırı riskini büyük oranda artırmaktadır

```
--(sanis@SANIYE-S-LAPTOP)~--
$ dirsearch -u https://partnerid.admin.redbull.com -e php,txt,zip,env,bak,conf
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, txt, zip, env, bak, conf | HTTP method: GET | Threads: 25 | Wordlist size: 12026

Output File: /home/sanis/reports/https_partnerid.admin.redbull.com/_26-03-12_02-50-02.txt

Target: https://partnerid.admin.redbull.com/

[02:50:02] Starting:
[02:50:40] 400 - 0B - /\.\.\.\.\.\.\.\.\.\.\.\.\.\.\.etc/passwd
[02:52:39] 200 - 33kB - /favicon.ico
[02:53:14] 200 - 1kB - /manifest.json
[02:54:08] 200 - 0B - /soap/

Task Completed

--(sanis@SANIYE-S-LAPTOP)~--
$
```

Subdomain 2: ontrack-q.redbull.com üzerinde yaptığım dirsearch taramasıyla 200 kodu veren graylog ve api gibi önemli dizinleri gördüm. Test sunucusu olarak kullanılan bu adreste, sistemin arka plandaki çalışma yapısını ve servislerini ele veren bu dosyaların dış erişime açık olması siber güvenlik açısından riskli bir veri açığıdır.

```
[03:02:21] 401 - 115B - /api/login.json
[03:02:21] 401 - 136B - /api/package_search/v4/documentation
[03:02:21] 401 - 112B - /api/profile
[03:02:21] 401 - 110B - /api/proxy
[03:02:21] 401 - 114B - /api/snapshots
[03:02:21] 401 - 122B - /api/spec/swagger.json
[03:02:21] 401 - 112B - /api/swagger
[03:02:21] 302 - 0B - /api/swagger-ui.html -> /swagger-ui/index.html
[03:02:21] 401 - 117B - /api/swagger.json
[03:02:21] 401 - 116B - /api/swagger.yml
[03:02:21] 401 - 117B - /api/swagger.yaml
[03:02:21] 401 - 121B - /api/swagger/ui/index
[03:02:21] 404 - 127B - /api/swagger/static/index.html
[03:02:21] 404 - 120B - /api/swagger/index.html
[03:02:21] 401 - 108B - /api/v1/
[03:02:21] 401 - 120B - /api/swagger/swagger
[03:02:21] 401 - 107B - /api/v1
[03:02:21] 401 - 117B - /api/timelion/run
[03:02:21] 401 - 120B - /api/v2/swagger.json
[03:02:21] 401 - 120B - /api/v1/swagger.yaml
[03:02:21] 401 - 107B - /api/v2
[03:02:21] 401 - 120B - /api/v1/swagger.json
[03:02:21] 401 - 108B - /api/v2/
[03:02:21] 401 - 107B - /api/v3
[03:02:21] 401 - 107B - /api/v4
[03:02:21] 401 - 120B - /api/v2/swagger.yaml
[03:02:21] 401 - 125B - /api/v2/helpdesk/discover
[03:02:21] 401 - 135B - /api/vendor/phpunit/phpunit/phpunit
[03:02:21] 401 - 112B - /api/version
[03:02:21] 401 - 111B - /api/whoami
[03:02:22] 301 - 169B - /assets -> http://frontend/assets/
[03:02:22] 403 - 555B - /assets/
[03:02:22] 404 - 102B - /backend/
[03:02:22] 401 - 118B - /backend/core/info.xml
[03:02:29] 200 - 318B - /favicon.ico
[03:02:30] 200 - 1kB - /graylog/

Task Completed
```

Subdomain 3: plonogram-d.redbull.com adresinde yaptığım taramada, yine /soap/ ve /manifest.json gibi dosyaların herkese açık olduğunu gördüm. Geliştirme aşamasındaki bir sitede bu dosyaların kilitli olmaması, sitenin mutfağına ait bilgilerin dışarı sızması anlamına geliyor. Bu durum, saldırganların sistemin nasıl kurulduğunu anlamasına yol açtığı için bir güvenlik açığıdır.

```
[03:02:30] 200 - 1kB - /graylog/

Task Completed

--(sanis@SANIYE-S-LAPTOP)~--
$ dirsearch -u https://planogram-d.redbull.com -e php,txt,zip,env,bak,conf
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, txt, zip, env, bak, conf | HTTP method: GET | Threads: 25 | Wordlist size: 12026

Output File: /home/sanis/reports/https_planogram-d.redbull.com/_26-03-12_03-07-47.txt

Target: https://planogram-d.redbull.com/

[03:07:47] Starting:
[03:08:33] 400 - 0B - /\.\.\.\.\.\.\.\.\.\.\.\.\.\.\.etc/passwd
[03:10:25] 200 - 33kB - /favicon.ico
[03:11:00] 200 - 306B - /manifest.json
[03:11:53] 200 - 0B - /soap/

Task Completed

--(sanis@SANIYE-S-LAPTOP)~--
```


Cephe 2: Zafiyet Avı (Vulnerability Assessment)

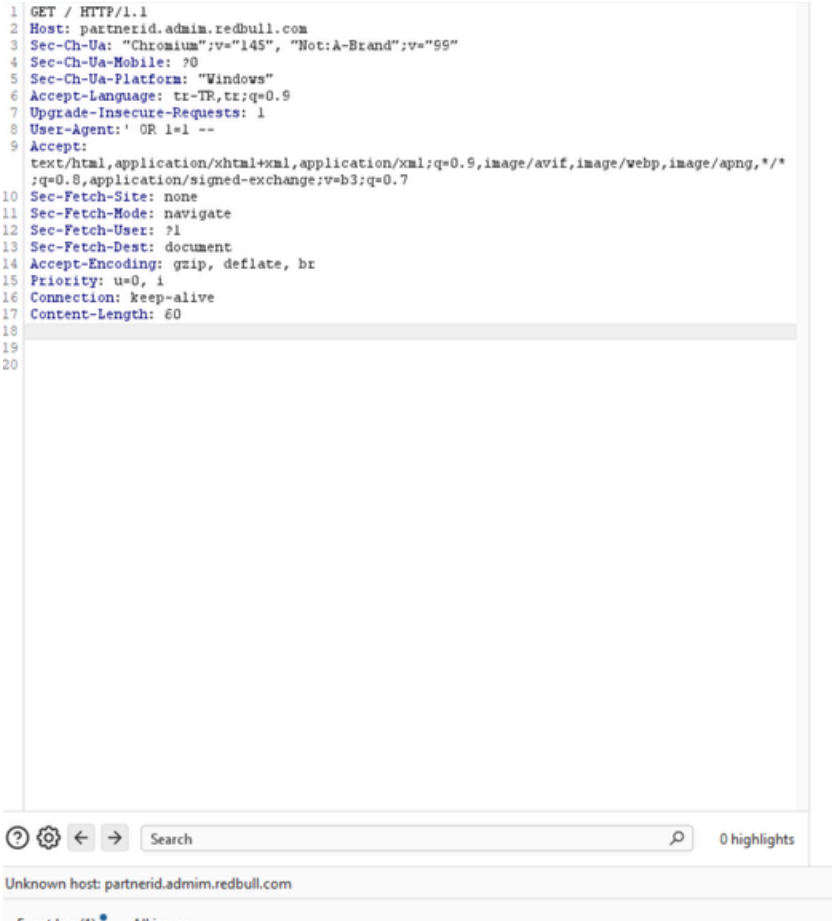
Recon aşamasında bulduğum sayfalara tarayıcıdan gittim ve arka planda Burp Suite'i (Proxy) çalıştırdım. Girdi Alanları (Input): Arama çubuklarında veya iletişim formlarında XSS veya SQL Injection tetiklemeye çalışın (' OR 1=1 -- veya <script>alert(1)</script>). Erişim Kontrolü: URL'deki parametrelerle oynayarak başkasının verisine ulaşmayı (IDOR) deneyin. Dosya Yükleme: Profil fotoğrafı yükleme alanlarına zararsız bir .txt veya uzantısı değiştirilmiş dosya yükleyerek filtreleri test edin. görevlerini yerine getirdim.

Cephe 3: Güvenlik Değerlendirme Raporu (Security Assessment)

Bu cephede Cephe 2 de yaptığım görevleri raporladım.

Subdomain 1 : partnerid.admin.redbull.com

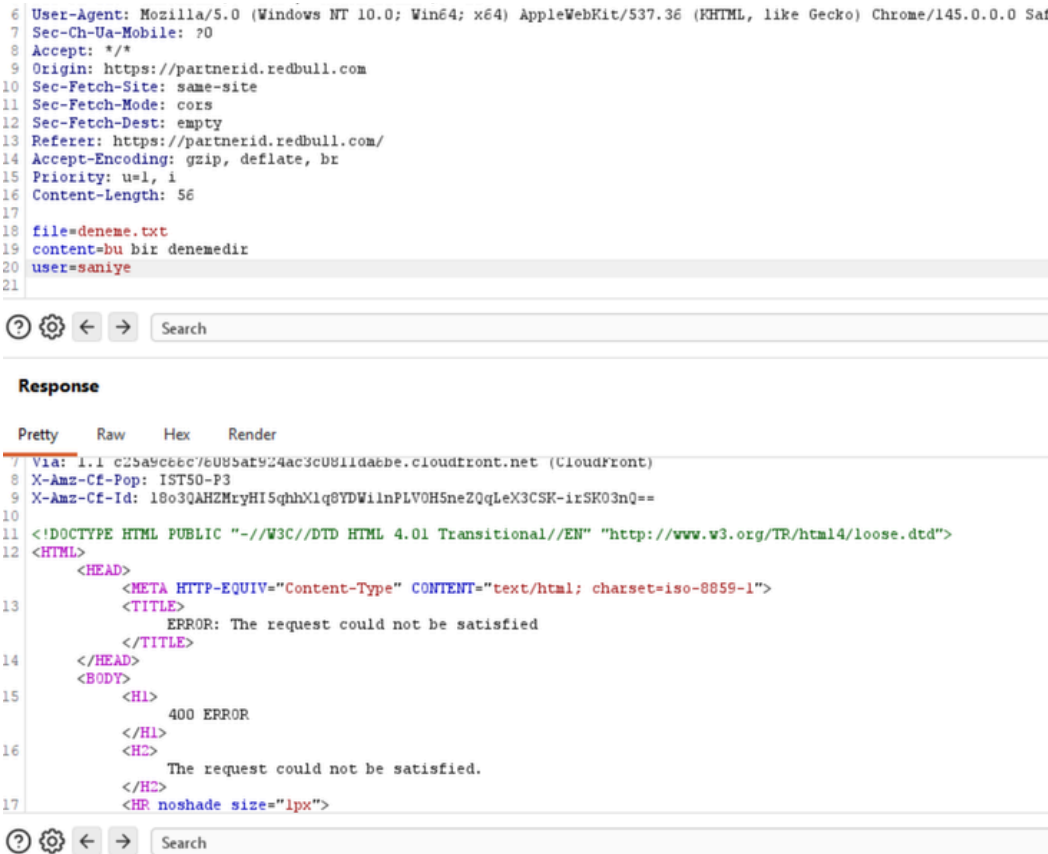
PartnerID sistemi sahte Host ve paket müdahalelerini "Unknown Host" uyarısıyla ağ seviyesinde engelleyen sağlam bir yapıya sahiptir. Eklenen SQLi ve dosya yükleme girişimlerinin reddedilmesi, Girdi Doğrulama filtrelerinin aktif çalıştığını ve sistemin saldırılara karşı dirençli olduğunu gösteriyor.



Bu kısımda User-Agent kısmını sildim ve yerine' OR 1=1 SQL injection kodunu yazdım “Unknown Host” uyarısını verdi saldırı paketinin sunucu katmanına ulaşmadan isim çözümüleme (DNS/Host) seviyesinde engellendiğini göstermektedir.



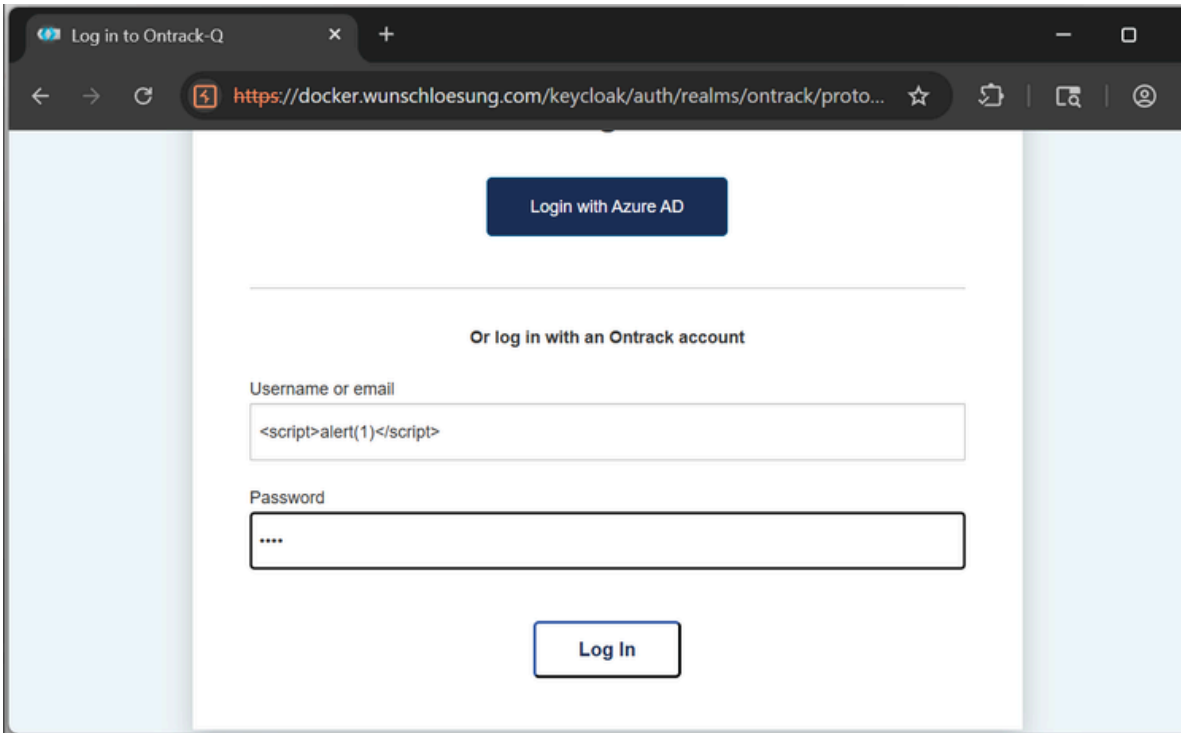
Burada partenerid.admim.com adresini ?user_id=105&v=1 adresi ile değiştirerek URL üzerinde değişiklik yaptım ve “Unknown Host” uyarısı verdi , gizli verilere erişim sağlayamadım.



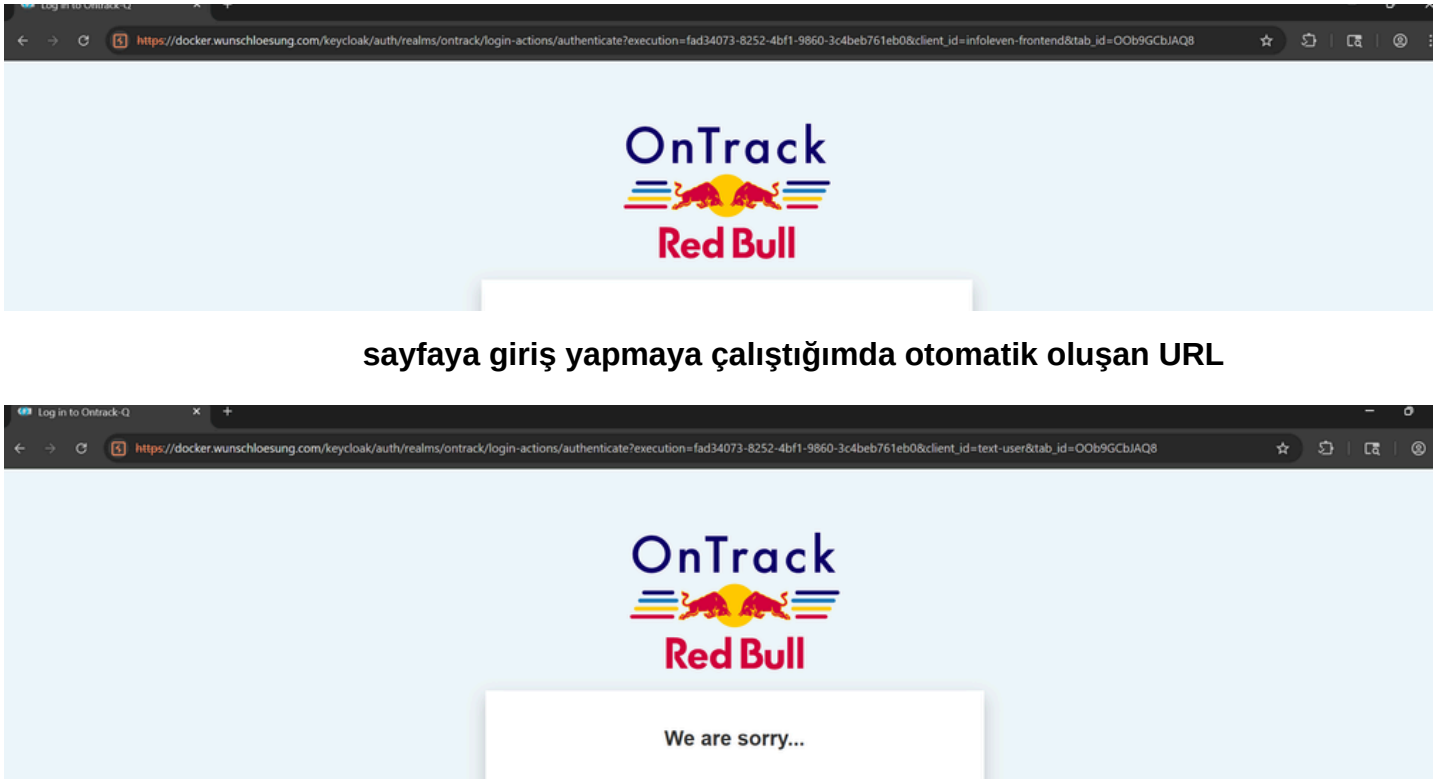
Burada “GET” isteği “POST” olarak değiştirilmiştir. Ve de görselde görülen file=deneme.txt content= bu bir denemedir user=saniye komutlarıyla txt dosyası oluşturulmaya çalıştım ve sunucudan 400 Bad Request durum kodunu aldım.

Subdomain 2: ontrack-q.redbull.com

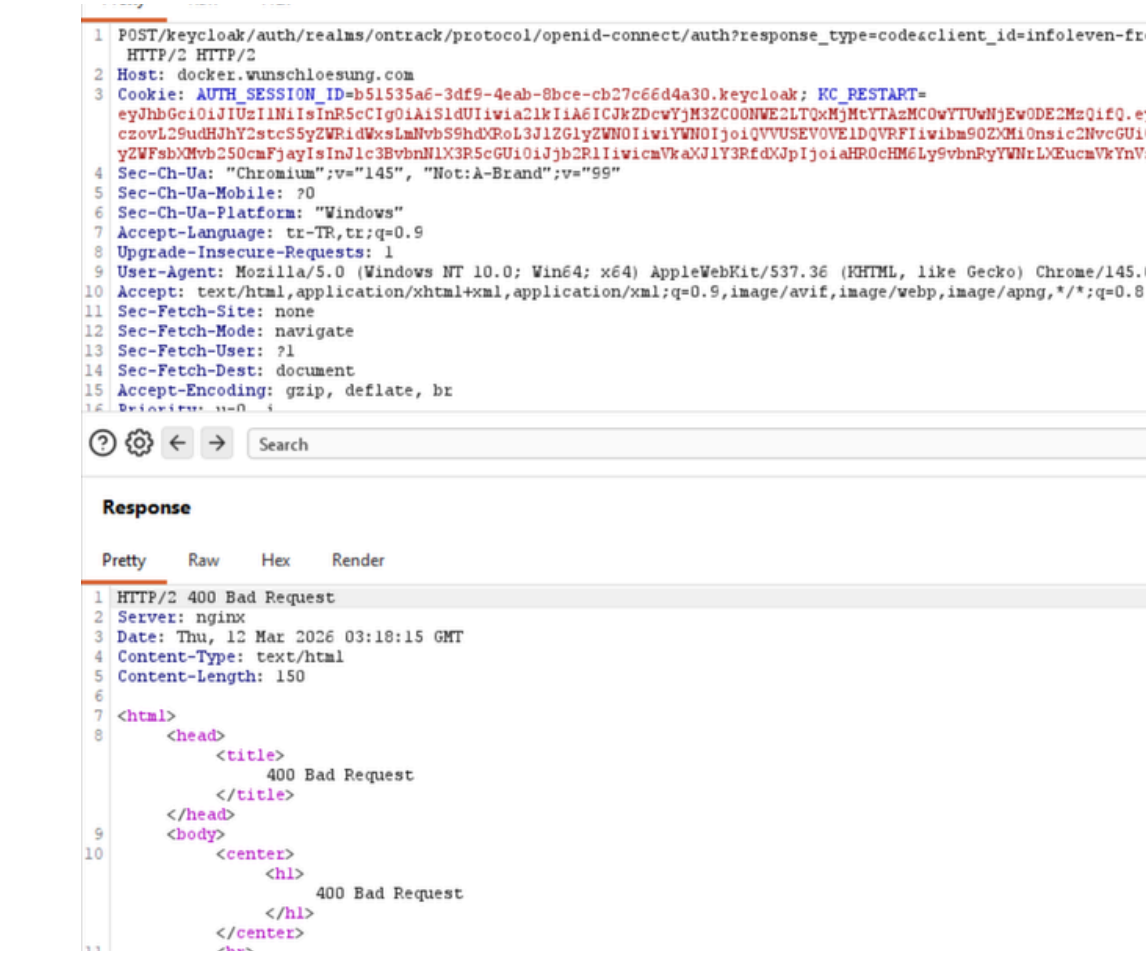
OnTrack-Q sistemi, giriş formunda denenen <script> gibi XSS payload'larını ve URL üzerinden yapılan test-user sisteme sızma işlemleri engellenmiştir . Text dosyası yüklemeye çalıştığımda 400 Bad Request ile reddedilmesi, sistemin girdi doğrulama filtrelerinin aktif çalıştığını ve saldırılara karşı dirençli olduğunu gösteriyor.



Ontrack-Q sayfasında kullanıcı adı kutusuna <script>alert(1)</script> yazarak XSS denemesi yaptım ama sistem hata vererek kodun çalışmasını engelledi.

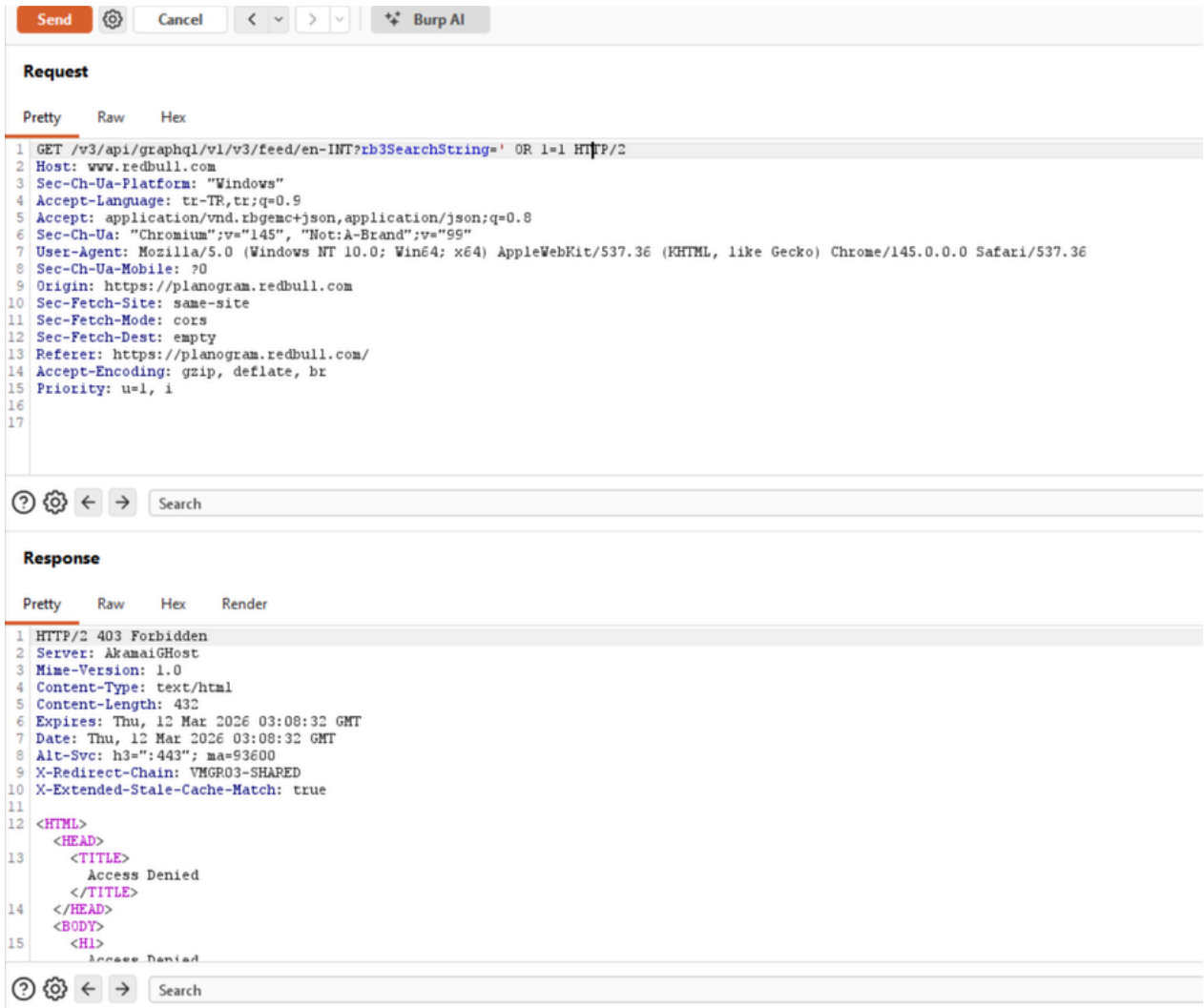


URL de id= kısmında infoluen_frontend kısmını silip test-user yazdım ancak sistemi erişime izin vermedi.



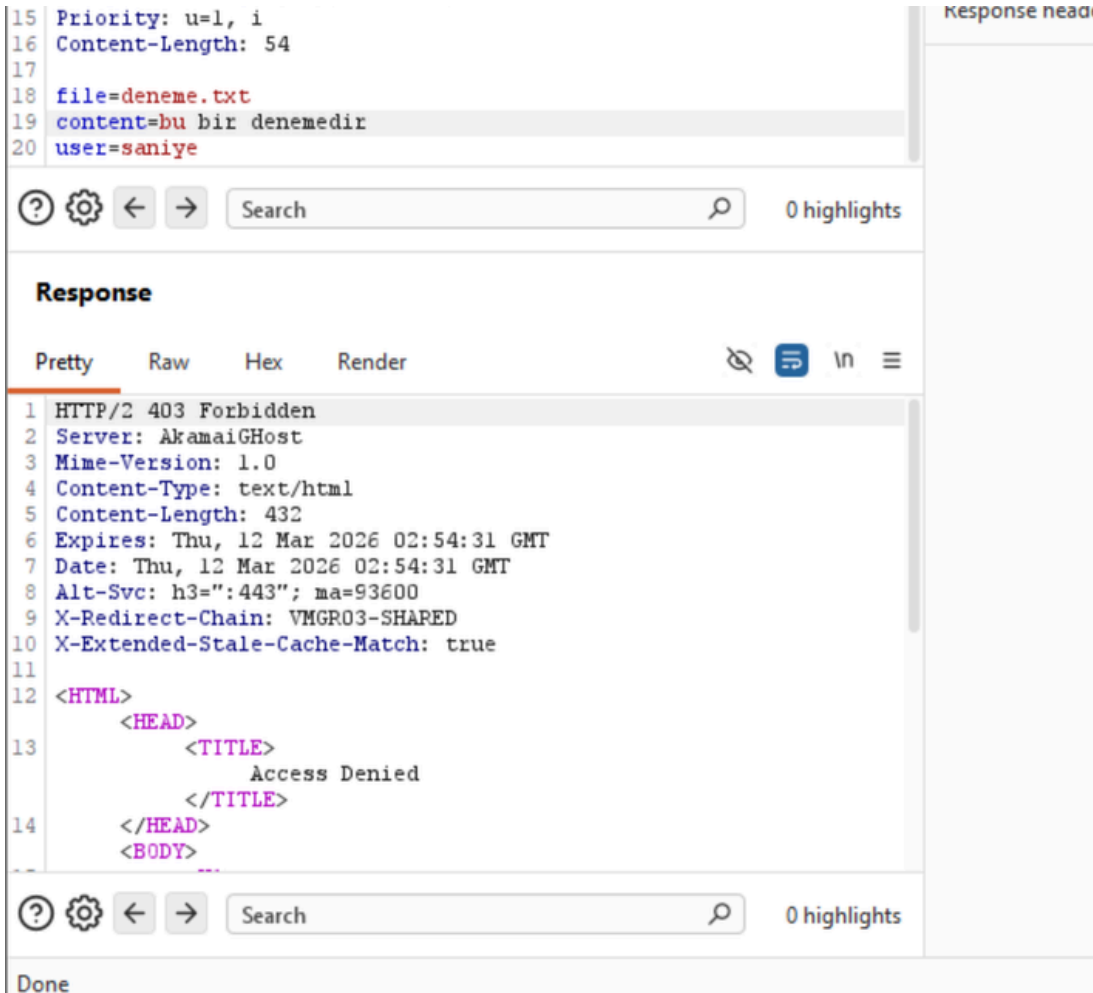
Subdomain 3: plonogram-d.redbull.com

Planogram sistemi, URL üzerinden denediğim ?user=admin gibi parametre değişimlerini ve sızma girişimlerini engelleyen sağlam bir yapıya sahiptir. İs"GET" satırına SQL injection kodunu eklediğimde 403 Forbidden uyarısıyla reddedilmesi, sistemin erişim kontrolü mekanizmasının aktif çalıştığını kanıtlamaktadır.



Burada "GET" isteği "POST" olarak değiştirilmiştir. Ve de satır sonuna file=deneme.txt content= bu bir denemedir user=saniye

komutları ekleyerek txt dosyası oluşturulmaya çalıştım ve sunucudan 400 Bad Request durum kodunu aldım.



Burada "GET" isteği "POST" olarak değiştirilmiştir. Ve de görselde görülen file=deneme.txt content= bu bir denemedir user=saniye

komutlarıyla txt dosyası oluşturulmaya çalıştım ve sunucudan 403 Forbidden durum kodunu aldım.

URL üzerinden denediğim ?user=admin gibi parametre değişikliğini "Unknown host" vermiştir bu durum sistemin erişim kontrolü ve güvenlik filtrelerinin aktif çalıştığını göstermektedir.

Bölüm D : Mühendislik Vizyonu (Reflection)

1.Etki Analizi (İmpact and CVSS Mantığı)

Hedef şirkette iki farklı XSS zafiyeti buldum. Birincisi, şirketin ana sayfasında kimsenin uğramadığı bir "Hakkımızda" sayfasındaki arama çubuğunda (Reflected XSS). İkincisi ise yöneticilerin girdiği iç ağıdaki (Admin Panel) yorumlar bölümünde (Stored XSS). Bu iki zafiyeti bir VDP yetkilisine nasıl açıklayabilirim?

Hakkımızda sayfasının risk seviyesi CVSS kriterleriyle değerlendirildiğinde risk seviyesi düşüktür. Kapsam değişmez. Kullanıcı etkileşimi gereklidir. Yetki almaya gerek yok.
Saldırı Vektörü: Saldırganın kurbanı istediği bağlantıya (URL) tıklamaya ikna etmesi gerekir. Kullanıcı etkileşimi şarttır.
Kullanıcı Kitlesi: Genel ziyaretçilerdir yetkileir sınırlıdır.
Kalıcılık:Geçicidir. Zararlı yazılım veritabanına kaydedilmez.

Admin Panel yorumlar bölümünde risk seviyesi CVSS kriterleriyle değerlendirildiğinde kritiktr. Kapsam değişebilir.
Kullanıcı etkileşimine gerek yoktur ya da çok düşüktür. Yetki almaya ihtiyacı yoktur.
Saldırı Vektörü: Kod veritabanına gömülmüştür. Saldırının erişilebilirliğini artırır.
Kullanıcı Kitlesi: Yönetici yetkisi olan kişilerdir. Saldırgan Session Cookie yi çalarsa tüm sisteme erişim sağlayabilir.
Kalıcılık: Kalıcıdır.

2.Çözüm Üretmek (Mitigation)

Yazılım ekibi size geri dönüş yaptı: "Bize SQL Injection açığını bulduğun için teşekkür ederiz. Arama kutusuna girilen ' (tek tırnak) karakterini yasaklayarak açığı kapattık."

Sadece belirli bir karakterin ya da kelimelerin kullanımı kısıtlanarak zayıf güvenlik önlemi almış olursunuz. Çünkü bu karakter yerine kullanılabilecek çok fazla alternatif karakter var noktalama işaretleri, özel karakterler gibi ya da o karakterin URL, Hex,Double karşılıklarını bulunarak da karakter yazılabilir Eğer SQL sorgusunda sayı bekleniyorsa tek tırnak kullanımını kısıtlamanın saldırgana bir etkisi yoktur. Bu tarz belirli bir karakter üzerinde kısıtlamaya gitmek kolayca aşılabilecek bir engeldir bunun yerine sadece izin verilen karakterleri belirlemek daha güvenli olabilir. Ya da SQL enjeksiyonunu önlemek için gelen veriyi de sorgunun bir parçası (Parametrelî Sorgular) olarak nitelendirilebilir. XSS riskine karşı ise encoding yapılarak zararlı yazılımların metin olarak algılanması sağlanabilir.